

CICD 掃描報告

專案名稱	CICD
掃描開始	2026年5月12日 上午 09:14:07
預設集合	Checkmarx Default
掃描時間	00h:01m:38s
被掃描的程式行數	52288
被掃描的檔案數	255
報告建立時間	2026年5月12日 上午 09:19:34
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979
團隊	planning
Checkmarx版本	9.6.5.1001 HF20
掃描類別	完整的
來源	LocalPath
漏洞密度	9/10000 (漏洞/LOC)
可見性	公開
掃描自訂欄位	

過濾器設置

嚴重程度：

包含在內: 高風險, 中風險, 低風險, 資訊

排除在外: 無

結果狀態：

包含在內: 校驗, 不可利用, 確認, 緊急, 推薦不可用

排除在外: 無

被分配給

包含在內: 全部

類別

包含在內:

未分類	全部
Custom	全部
PCI DSS v3.2.1	全部
OWASP Top 10 2013	全部
FISMA 2014	全部
NIST SP 800-53	全部
OWASP Top 10 2017	全部
OWASP Mobile Top 10 2016	全部
OWASP Top 10 API	全部
ASD STIG 4.10	全部
OWASP Top 10 2010	全部
CWE top 25	全部
MOIS(KISA) Secure	全部

Coding 2021	
OWASP ASVS	全部
OWASP Top 10 2021	全部
SANS top 25	全部
ASA Mobile Premium	全部
ASA Premium	全部
Top Tier	全部
ASD STIG 5.3	全部
Base Preset	全部
OWASP Top 10 API 2023	全部
PCI DSS v4.0	全部

排除在外:

未分類	無
Custom	無
PCI DSS v3.2.1	無
OWASP Top 10 2013	無
FISMA 2014	無
NIST SP 800-53	無
OWASP Top 10 2017	無
OWASP Mobile Top 10 2016	無
OWASP Top 10 API	無
ASD STIG 4.10	無
OWASP Top 10 2010	無
CWE top 25	無
MOIS(KISA) Secure Coding 2021	無
OWASP ASVS	無
OWASP Top 10 2021	無
SANS top 25	無
ASA Mobile Premium	無
ASA Premium	無
Top Tier	無
ASD STIG 5.3	無
Base Preset	無
OWASP Top 10 API 2023	無

PCI DSS v4.0

無

結果限制

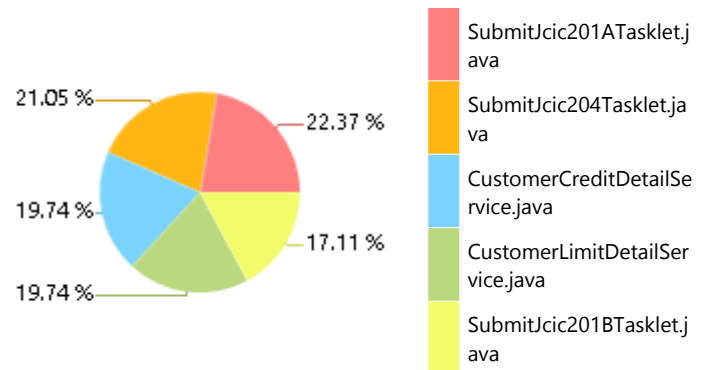
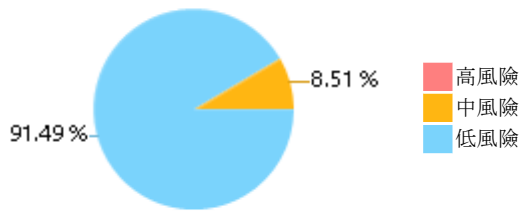
每次查詢的結果限制設置為 50

選取的查詢

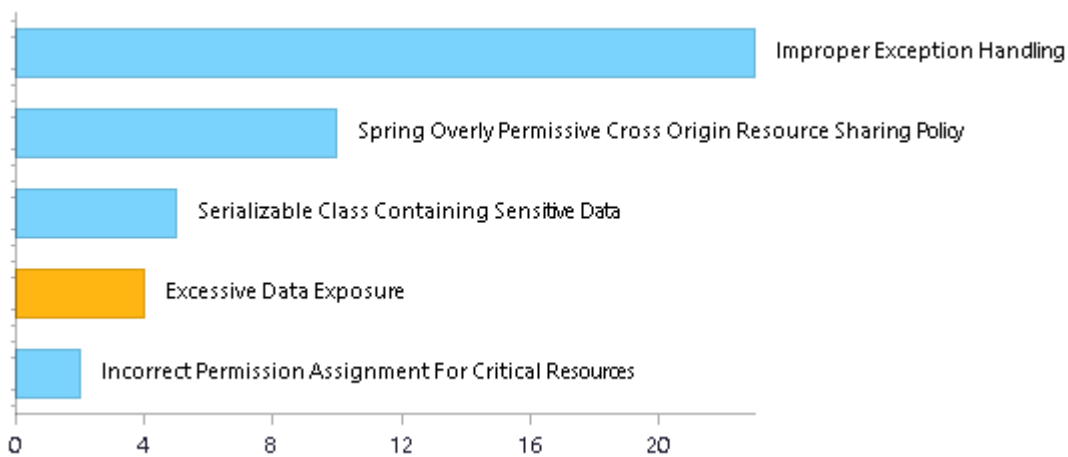
選取的查詢列出在 [掃描結果摘要](#)

掃描結果摘要

最容易受攻擊的檔案



數量最多的前5類漏洞



掃描總結 - OWASP Top 10 2017

有關可見性和風險的詳細資訊及闡述參見：[OWASP Top 10 2017](#)

Category	Threat Agent	Exploitability	Weakness Prevalence	Weakness Detectability	Technical Impact	Business Impact	Issues Found	Best Fix Locations
A1-Injection*	App. Specific	EASY	COMMON	EASY	SEVERE	App. Specific	0	0
A2-Broken Authentication*	App. Specific	EASY	COMMON	AVERAGE	SEVERE	App. Specific	0	0
A3-Sensitive Data Exposure*	App. Specific	AVERAGE	WIDESPREAD	AVERAGE	SEVERE	App. Specific	5	3
A4-XML External Entities (XXE)	App. Specific	AVERAGE	COMMON	EASY	SEVERE	App. Specific	0	0
A5-Broken Access Control*	App. Specific	AVERAGE	COMMON	AVERAGE	SEVERE	App. Specific	0	0
A6-Security Misconfiguration *	App. Specific	EASY	WIDESPREAD	EASY	MODERATE	App. Specific	3	3
A7-Cross-Site Scripting (XSS)*	App. Specific	EASY	WIDESPREAD	EASY	MODERATE	App. Specific	0	0
A8-Insecure Deserialization	App. Specific	DIFFICULT	COMMON	AVERAGE	SEVERE	App. Specific	0	0
A9-Using Components with Known Vulnerabilities*	App. Specific	AVERAGE	WIDESPREAD	AVERAGE	MODERATE	App. Specific	0	0
A10-Insufficient Logging & Monitoring	App. Specific	AVERAGE	WIDESPREAD	DIFFICULT	MODERATE	App. Specific	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - OWASP Top 10 2021

Category	Issues Found	Best Fix Locations
A1-Broken Access Control*	4	4
A2-Cryptographic Failures	0	0
A3-Injection*	0	0
A4-Insecure Design*	31	29
A5-Security Misconfiguration*	0	0
A6-Vulnerable and Outdated Components*	0	0
A7-Identification and Authentication Failures*	11	11
A8-Software and Data Integrity Failures*	0	0
A9-Security Logging and Monitoring Failures	209	209
A10-Server-Side Request Forgery	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - OWASP Top 10 2013

有關可見性和風險的詳細資訊及闡述參見：[OWASP Top 10 2013](#)

Category	Threat Agent	Attack Vectors	Weakness Prevalence	Weakness Detectability	Technical Impact	Business Impact	Issues Found	Best Fix Locations
A1-Injection*	EXTERNAL, INTERNAL, ADMIN USERS	EASY	COMMON	AVERAGE	SEVERE	ALL DATA	0	0
A2-Broken Authentication and Session Management*	EXTERNAL, INTERNAL USERS	AVERAGE	WIDESPREAD	AVERAGE	SEVERE	AFFECTED DATA AND FUNCTIONS	0	0
A3-Cross-Site Scripting (XSS)*	EXTERNAL, INTERNAL, ADMIN USERS	AVERAGE	VERY WIDESPREAD	EASY	MODERATE	AFFECTED DATA AND SYSTEM	0	0
A4-Insecure Direct Object References	SYSTEM USERS	EASY	COMMON	EASY	MODERATE	EXPOSED DATA	0	0
A5-Security Misconfiguration *	EXTERNAL, INTERNAL, ADMIN USERS	EASY	COMMON	EASY	MODERATE	ALL DATA AND SYSTEM	1	1
A6-Sensitive Data Exposure*	EXTERNAL, INTERNAL, ADMIN USERS, USERS BROWSERS	DIFFICULT	UNCOMMON	AVERAGE	SEVERE	EXPOSED DATA	5	3
A7-Missing Function Level Access Control*	EXTERNAL, INTERNAL USERS	EASY	COMMON	AVERAGE	MODERATE	EXPOSED DATA AND FUNCTIONS	0	0
A8-Cross-Site Request Forgery (CSRF)	USERS BROWSERS	AVERAGE	COMMON	EASY	MODERATE	AFFECTED DATA AND FUNCTIONS	0	0
A9-Using Components with Known Vulnerabilities*	EXTERNAL USERS, AUTOMATED TOOLS	AVERAGE	WIDESPREAD	DIFFICULT	MODERATE	AFFECTED DATA AND FUNCTIONS	0	0
A10-Unvalidated Redirects and Forwards	USERS BROWSERS	AVERAGE	WIDESPREAD	DIFFICULT	MODERATE	AFFECTED DATA AND FUNCTIONS	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - PCI DSS v3.2.1

Category	Issues Found	Best Fix Locations
PCI DSS (3.2.1) - 6.5.1 - Injection flaws - particularly SQL injection	0	0
PCI DSS (3.2.1) - 6.5.2 - Buffer overflows	0	0
PCI DSS (3.2.1) - 6.5.3 - Insecure cryptographic storage*	0	0
PCI DSS (3.2.1) - 6.5.4 - Insecure communications*	0	0
PCI DSS (3.2.1) - 6.5.5 - Improper error handling*	24	24
PCI DSS (3.2.1) - 6.5.7 - Cross-site scripting (XSS)*	0	0
PCI DSS (3.2.1) - 6.5.8 - Improper access control*	0	0
PCI DSS (3.2.1) - 6.5.9 - Cross-site request forgery	0	0
PCI DSS (3.2.1) - 6.5.10 - Broken authentication and session management	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - FISMA 2014

Category	Description	Issues Found	Best Fix Locations
Access Control*	Organizations must limit information system access to authorized users, processes acting on behalf of authorized users, or devices (including other information systems) and to the types of transactions and functions that authorized users are permitted to exercise.	2	2
Audit And Accountability*	Organizations must: (i) create, protect, and retain information system audit records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful, unauthorized, or inappropriate information system activity; and (ii) ensure that the actions of individual information system users can be uniquely traced to those users so they can be held accountable for their actions.	0	0
Configuration Management*	Organizations must: (i) establish and maintain baseline configurations and inventories of organizational information systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles; and (ii) establish and enforce security configuration settings for information technology products employed in organizational information systems.	1	1
Identification And Authentication*	Organizations must identify information system users, processes acting on behalf of users, or devices and authenticate (or verify) the identities of those users, processes, or devices, as a prerequisite to allowing access to organizational information systems.	0	0
Media Protection	Organizations must: (i) protect information system media, both paper and digital; (ii) limit access to information on information system media to authorized users; and (iii) sanitize or destroy information system media before disposal or release for reuse.	0	0
System And Communications Protection	Organizations must: (i) monitor, control, and protect organizational communications (i.e., information transmitted or received by organizational information systems) at the external boundaries and key internal boundaries of the information systems; and (ii) employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within organizational information systems.	0	0
System And Information Integrity*	Organizations must: (i) identify, report, and correct information and information system flaws in a timely manner; (ii) provide protection from malicious code at appropriate locations within organizational information systems; and (iii) monitor information system security alerts and advisories and take appropriate actions in response.	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - NIST SP 800-53

Category	Issues Found	Best Fix Locations
AC-12 Session Termination (P2)	0	0
AC-3 Access Enforcement (P1)*	2	2
AC-4 Information Flow Enforcement (P1)	0	0
AC-6 Least Privilege (P1)	0	0
AU-9 Protection of Audit Information (P1)	0	0
CM-6 Configuration Settings (P2)	0	0
IA-5 Authenticator Management (P1)	0	0
IA-6 Authenticator Feedback (P2)	0	0
IA-8 Identification and Authentication (Non-Organizational Users) (P1)	0	0
SC-12 Cryptographic Key Establishment and Management (P1)	0	0
SC-13 Cryptographic Protection (P1)	0	0
SC-17 Public Key Infrastructure Certificates (P1)	0	0
SC-18 Mobile Code (P2)	0	0
SC-23 Session Authenticity (P1)*	0	0
SC-28 Protection of Information at Rest (P1)*	0	0
SC-4 Information in Shared Resources (P1)	0	0
SC-5 Denial of Service Protection (P1)*	23	23
SC-8 Transmission Confidentiality and Integrity (P1)	0	0
SI-10 Information Input Validation (P1)*	0	0
SI-11 Error Handling (P2)*	1	1
SI-15 Information Output Filtering (P0)	0	0
SI-16 Memory Protection (P1)*	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - OWASP Mobile Top 10 2016

Category	Description	Issues Found	Best Fix Locations
M1-Improper Platform Usage*	This category covers misuse of a platform feature or failure to use platform security controls. It might include Android intents, platform permissions, misuse of TouchID, the Keychain, or some other security control that is part of the mobile operating system. There are several ways that mobile apps can experience this risk.	0	0
M2-Insecure Data Storage*	This category covers insecure data storage and unintended data leakage.	0	0
M3-Insecure Communication*	This category covers poor handshaking, incorrect SSL versions, weak negotiation, cleartext communication of sensitive assets, etc.	0	0
M4-Insecure Authentication*	This category captures notions of authenticating the end user or bad session management. This can include: -Failing to identify the user at all when that should be required -Failure to maintain the user's identity when it is required -Weaknesses in session management	0	0
M5-Insufficient Cryptography*	The code applies cryptography to a sensitive information asset. However, the cryptography is insufficient in some way. Note that anything and everything related to TLS or SSL goes in M3. Also, if the app fails to use cryptography at all when it should, that probably belongs in M2. This category is for issues where cryptography was attempted, but it wasn't done correctly.	0	0
M6-Insecure Authorization*	This is a category to capture any failures in authorization (e.g., authorization decisions in the client side, forced browsing, etc.). It is distinct from authentication issues (e.g., device enrolment, user identification, etc.). If the app does not authenticate users at all in a situation where it should (e.g., granting anonymous access to some resource or service when authenticated and authorized access is required), then that is an authentication failure not an authorization failure.	0	0
M7-Client Code Quality*	This category is the catch-all for code-level implementation problems in the mobile client. That's distinct from server-side coding mistakes. This would capture things like buffer overflows, format string vulnerabilities, and various other code-level mistakes where the solution is to rewrite some code that's running on the mobile device.	0	0
M8-Code Tampering*	This category covers binary patching, local resource modification, method hooking, method swizzling, and dynamic memory modification. Once the application is delivered to the mobile device, the code and data resources are resident there. An attacker can either directly modify the code, change the contents of memory dynamically, change or replace the system APIs that the application uses, or	0	0

	modify the application's data and resources. This can provide the attacker a direct method of subverting the intended use of the software for personal or monetary gain.		
M9-Reverse Engineering*	This category includes analysis of the final core binary to determine its source code, libraries, algorithms, and other assets. Software such as IDA Pro, Hopper, otool, and other binary inspection tools give the attacker insight into the inner workings of the application. This may be used to exploit other nascent vulnerabilities in the application, as well as revealing information about back end servers, cryptographic constants and ciphers, and intellectual property.	0	0
M10-Extraneous Functionality*	Often, developers include hidden backdoor functionality or other internal development security controls that are not intended to be released into a production environment. For example, a developer may accidentally include a password as a comment in a hybrid app. Another example includes disabling of 2-factor authentication during testing.	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - OWASP Top 10 API

Category	Issues Found	Best Fix Locations
API1-Broken Object Level Authorization	0	0
API2-Broken Authentication*	0	0
API3-Excessive Data Exposure	1	1
API4-Lack of Resources and Rate Limiting	0	0
API5-Broken Function Level Authorization	0	0
API6-Mass Assignment	0	0
API7-Security Misconfiguration*	0	0
API8-Injection*	0	0
API9-Improper Assets Management	0	0
API10-Insufficient Logging and Monitoring	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - Custom

Category	Issues Found	Best Fix Locations
Must audit	0	0
Check	0	0
Optional	0	0

掃描總結 - PCI DSS v4.0

Category	Issues Found	Best Fix Locations
PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development*	46	44

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - ASD STIG 4.10

Category	Issues Found	Best Fix Locations
APSC-DV-000640 - CAT II The application must provide audit record generation capability for the renewal of session IDs.	0	0
APSC-DV-000650 - CAT II The application must not write sensitive data into the application logs.	0	0
APSC-DV-000660 - CAT II The application must provide audit record generation capability for session timeouts.	0	0
APSC-DV-000670 - CAT II The application must record a time stamp indicating when the event occurred.	0	0
APSC-DV-000680 - CAT II The application must provide audit record generation capability for HTTP headers including User-Agent, Referer, GET, and POST.	0	0
APSC-DV-000690 - CAT II The application must provide audit record generation capability for connecting system IP addresses.	0	0
APSC-DV-000700 - CAT II The application must record the username or user ID of the user associated with the event.	0	0
APSC-DV-000710 - CAT II The application must generate audit records when successful/unsuccessful attempts to grant privileges occur.	0	0
APSC-DV-000720 - CAT II The application must generate audit records when successful/unsuccessful attempts to access security objects occur.	0	0
APSC-DV-000730 - CAT II The application must generate audit records when successful/unsuccessful attempts to access security levels occur.	0	0
APSC-DV-000740 - CAT II The application must generate audit records when successful/unsuccessful attempts to access categories of information (e.g., classification levels) occur.	0	0
APSC-DV-000750 - CAT II The application must generate audit records when successful/unsuccessful attempts to modify privileges occur.	0	0
APSC-DV-000760 - CAT II The application must generate audit records when successful/unsuccessful attempts to modify security objects occur.	0	0
APSC-DV-000770 - CAT II The application must generate audit records when successful/unsuccessful attempts to modify security levels occur.	0	0
APSC-DV-000780 - CAT II The application must generate audit records when successful/unsuccessful attempts to modify categories of information (e.g., classification levels) occur.	0	0
APSC-DV-000790 - CAT II The application must generate audit records when successful/unsuccessful attempts to delete privileges occur.	0	0
APSC-DV-000800 - CAT II The application must generate audit records when successful/unsuccessful attempts to delete security levels occur.	0	0
APSC-DV-000810 - CAT II The application must generate audit records when successful/unsuccessful attempts to delete application database security objects occur.	0	0
APSC-DV-000820 - CAT II The application must generate audit records when successful/unsuccessful attempts to delete categories of information (e.g., classification levels) occur.	0	0
APSC-DV-000830 - CAT II The application must generate audit records when successful/unsuccessful logon attempts occur.	0	0
APSC-DV-000840 - CAT II The application must generate audit records for privileged activities or other system-level access.	0	0
APSC-DV-000850 - CAT II The application must generate audit records showing starting and ending time for user access to the system.	0	0
APSC-DV-000860 - CAT II The application must generate audit records when successful/unsuccessful accesses to objects occur.	0	0

APSC-DV-000870 - CAT II The application must generate audit records for all direct access to the information system.	0	0
APSC-DV-000880 - CAT II The application must generate audit records for all account creations, modifications, disabling, and termination events.	0	0
APSC-DV-000910 - CAT II The application must initiate session auditing upon startup.	0	0
APSC-DV-000940 - CAT II The application must log application shutdown events.	0	0
APSC-DV-000950 - CAT II The application must log destination IP addresses.	0	0
APSC-DV-000960 - CAT II The application must log user actions involving access to data.	0	0
APSC-DV-000970 - CAT II The application must log user actions involving changes to data.	0	0
APSC-DV-000980 - CAT II The application must produce audit records containing information to establish when (date and time) the events occurred.	0	0
APSC-DV-000990 - CAT II The application must produce audit records containing enough information to establish which component, feature or function of the application triggered the audit event.	0	0
APSC-DV-001000 - CAT II When using centralized logging; the application must include a unique identifier in order to distinguish itself from other application logs.	0	0
APSC-DV-001010 - CAT II The application must produce audit records that contain information to establish the outcome of the events.	0	0
APSC-DV-001020 - CAT II The application must generate audit records containing information that establishes the identity of any individual or process associated with the event.	0	0
APSC-DV-001030 - CAT II The application must generate audit records containing the full-text recording of privileged commands or the individual identities of group account users.	0	0
APSC-DV-001040 - CAT II The application must implement transaction recovery logs when transaction based.	0	0
APSC-DV-001050 - CAT II The application must provide centralized management and configuration of the content to be captured in audit records generated by all application components.	0	0
APSC-DV-001070 - CAT II The application must off-load audit records onto a different system or media than the system being audited.	0	0
APSC-DV-001080 - CAT II The application must be configured to write application logs to a centralized log repository.	0	0
APSC-DV-001090 - CAT II The application must provide an immediate warning to the SA and ISSO (at a minimum) when allocated audit record storage volume reaches 75% of repository maximum audit record storage capacity.	0	0
APSC-DV-001100 - CAT II Applications categorized as having a moderate or high impact must provide an immediate real-time alert to the SA and ISSO (at a minimum) for all audit failure events.	0	0
APSC-DV-001110 - CAT II The application must alert the ISSO and SA (at a minimum) in the event of an audit processing failure.	0	0
APSC-DV-001120 - CAT II The application must shut down by default upon audit failure (unless availability is an overriding concern).	0	0
APSC-DV-001130 - CAT II The application must provide the capability to centrally review and analyze audit records from multiple components within the system.	0	0
APSC-DV-001140 - CAT II The application must provide the capability to filter audit records for events of interest based upon organization-defined criteria.	0	0
APSC-DV-001150 - CAT II The application must provide an audit reduction capability that supports on-demand reporting requirements.	0	0
APSC-DV-001160 - CAT II The application must provide an audit reduction capability that supports on-demand audit review and analysis.	0	0
APSC-DV-001170 - CAT II The application must provide an audit reduction capability that supports after-the-fact investigations of security incidents.	0	0
APSC-DV-001180 - CAT II The application must provide a report generation capability that supports on-demand audit review and analysis.	0	0

APSC-DV-001190 - CAT II The application must provide a report generation capability that supports on-demand reporting requirements.	0	0
APSC-DV-001200 - CAT II The application must provide a report generation capability that supports after-the-fact investigations of security incidents.	0	0
APSC-DV-001210 - CAT II The application must provide an audit reduction capability that does not alter original content or time ordering of audit records.	0	0
APSC-DV-001220 - CAT II The application must provide a report generation capability that does not alter original content or time ordering of audit records.	0	0
APSC-DV-001250 - CAT II The applications must use internal system clocks to generate time stamps for audit records.	0	0
APSC-DV-001260 - CAT II The application must record time stamps for audit records that can be mapped to Coordinated Universal Time (UTC) or Greenwich Mean Time (GMT).	0	0
APSC-DV-001270 - CAT II The application must record time stamps for audit records that meet a granularity of one second for a minimum degree of precision.	0	0
APSC-DV-001280 - CAT II The application must protect audit information from any type of unauthorized read access.	0	0
APSC-DV-001290 - CAT II The application must protect audit information from unauthorized modification.	0	0
APSC-DV-001300 - CAT II The application must protect audit information from unauthorized deletion.	0	0
APSC-DV-001310 - CAT II The application must protect audit tools from unauthorized access.	0	0
APSC-DV-001320 - CAT II The application must protect audit tools from unauthorized modification.	0	0
APSC-DV-001330 - CAT II The application must protect audit tools from unauthorized deletion.	0	0
APSC-DV-001340 - CAT II The application must back up audit records at least every seven days onto a different system or system component than the system or component being audited.	0	0
APSC-DV-001570 - CAT II The application must electronically verify Personal Identity Verification (PIV) credentials.	0	0
APSC-DV-001350 - CAT II The application must use cryptographic mechanisms to protect the integrity of audit information.	0	0
APSC-DV-001360 - CAT II Application audit tools must be cryptographically hashed.	0	0
APSC-DV-001370 - CAT II The integrity of the audit tools must be validated by checking the files for changes in the cryptographic hash value.	0	0
APSC-DV-001390 - CAT II The application must prohibit user installation of software without explicit privileged status.	0	0
APSC-DV-001410 - CAT II The application must enforce access restrictions associated with changes to application configuration.	0	0
APSC-DV-001420 - CAT II The application must audit who makes configuration changes to the application.	0	0
APSC-DV-001430 - CAT II The application must have the capability to prevent the installation of patches, service packs, or application components without verification the software component has been digitally signed using a certificate that is recognized and approved by the orga	0	0
APSC-DV-001440 - CAT II The applications must limit privileges to change the software resident within software libraries.	0	0
APSC-DV-001460 - CAT II An application vulnerability assessment must be conducted.	0	0
APSC-DV-001480 - CAT II The application must prevent program execution in accordance with organization-defined policies regarding software program usage and restrictions, and/or rules authorizing the terms and conditions of software program usage.	0	0
APSC-DV-001490 - CAT II The application must employ a deny-all, permit-by-exception (whitelist) policy to allow the execution of authorized software programs.	0	0
APSC-DV-001500 - CAT II The application must be configured to disable non-essential capabilities.	0	0
APSC-DV-001510 - CAT II The application must be configured to use only functions, ports, and protocols permitted to it in the PPSM CAL.	0	0

APSC-DV-001520 - CAT II The application must require users to reauthenticate when organization-defined circumstances or situations require reauthentication.	0	0
APSC-DV-001530 - CAT II The application must require devices to reauthenticate when organization-defined circumstances or situations requiring reauthentication.	0	0
APSC-DV-001540 - CAT I The application must uniquely identify and authenticate organizational users (or processes acting on behalf of organizational users).	0	0
APSC-DV-001550 - CAT II The application must use multifactor (Alt. Token) authentication for network access to privileged accounts.	0	0
APSC-DV-001560 - CAT II The application must accept Personal Identity Verification (PIV) credentials.	0	0
APSC-DV-001580 - CAT II The application must use multifactor (e.g., CAC, Alt. Token) authentication for network access to non-privileged accounts.	0	0
APSC-DV-001590 - CAT II The application must use multifactor (Alt. Token) authentication for local access to privileged accounts.	0	0
APSC-DV-001600 - CAT II The application must use multifactor (e.g., CAC, Alt. Token) authentication for local access to non-privileged accounts.	0	0
APSC-DV-001610 - CAT II The application must ensure users are authenticated with an individual authenticator prior to using a group authenticator.	0	0
APSC-DV-001620 - CAT II The application must implement replay-resistant authentication mechanisms for network access to privileged accounts.	0	0
APSC-DV-001630 - CAT II The application must implement replay-resistant authentication mechanisms for network access to non-privileged accounts.	0	0
APSC-DV-001640 - CAT II The application must utilize mutual authentication when endpoint device non-repudiation protections are required by DoD policy or by the data owner.	0	0
APSC-DV-001650 - CAT II The application must authenticate all network connected endpoint devices before establishing any connection.	0	0
APSC-DV-001660 - CAT II Service-Oriented Applications handling non-releasable data must authenticate endpoint devices via mutual SSL/TLS.	0	0
APSC-DV-001670 - CAT II The application must disable device identifiers after 35 days of inactivity unless a cryptographic certificate is used for authentication.	0	0
APSC-DV-001680 - CAT I The application must enforce a minimum 15-character password length.	0	0
APSC-DV-001690 - CAT II The application must enforce password complexity by requiring that at least one upper-case character be used.	0	0
APSC-DV-001700 - CAT II The application must enforce password complexity by requiring that at least one lower-case character be used.	0	0
APSC-DV-001710 - CAT II The application must enforce password complexity by requiring that at least one numeric character be used.	0	0
APSC-DV-001720 - CAT II The application must enforce password complexity by requiring that at least one special character be used.	0	0
APSC-DV-001730 - CAT II The application must require the change of at least 8 of the total number of characters when passwords are changed.	0	0
APSC-DV-001740 - CAT I The application must only store cryptographic representations of passwords.	0	0
APSC-DV-001850 - CAT I The application must not display passwords/PINs as clear text.	0	0
APSC-DV-001750 - CAT I The application must transmit only cryptographically-protected passwords.	0	0
APSC-DV-001760 - CAT II The application must enforce 24 hours/1 day as the minimum password lifetime.	0	0
APSC-DV-001770 - CAT II The application must enforce a 60-day maximum password lifetime restriction.	0	0
APSC-DV-001780 - CAT II The application must prohibit password reuse for a minimum of five generations.	0	0
APSC-DV-001790 - CAT II The application must allow the use of a temporary password for system logons with an immediate change to a permanent password.	0	0

APSC-DV-001795 - CAT II The application password must not be changeable by users other than the administrator or the user with which the password is associated.	0	0
APSC-DV-001800 - CAT II The application must terminate existing user sessions upon account deletion.	0	0
APSC-DV-001820 - CAT I The application, when using PKI-based authentication, must enforce authorized access to the corresponding private key.	0	0
APSC-DV-001830 - CAT II The application must map the authenticated identity to the individual user or group account for PKI-based authentication.	0	0
APSC-DV-001870 - CAT II The application must uniquely identify and authenticate non-organizational users (or processes acting on behalf of non-organizational users).	0	0
APSC-DV-001810 - CAT I The application, when utilizing PKI-based authentication, must validate certificates by constructing a certification path (which includes status information) to an accepted trust anchor.	0	0
APSC-DV-001840 - CAT II The application, for PKI-based authentication, must implement a local cache of revocation data to support path discovery and validation in case of the inability to access revocation information via the network.	0	0
APSC-DV-001860 - CAT II The application must use mechanisms meeting the requirements of applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance for authentication to a cryptographic module.	0	0
APSC-DV-001880 - CAT II The application must accept Personal Identity Verification (PIV) credentials from other federal agencies.	0	0
APSC-DV-001890 - CAT II The application must electronically verify Personal Identity Verification (PIV) credentials from other federal agencies.	0	0
APSC-DV-002050 - CAT II Applications making SAML assertions must use FIPS-approved random numbers in the generation of SessionIndex in the SAML element AuthnStatement.	0	0
APSC-DV-001900 - CAT II The application must accept FICAM-approved third-party credentials.	0	0
APSC-DV-001910 - CAT II The application must conform to FICAM-issued profiles.	0	0
APSC-DV-001930 - CAT II Applications used for non-local maintenance sessions must audit non-local maintenance and diagnostic sessions for organization-defined auditable events.	0	0
APSC-DV-000310 - CAT III The application must have a process, feature or function that prevents removal or disabling of emergency accounts.	0	0
APSC-DV-001940 - CAT II Applications used for non-local maintenance sessions must implement cryptographic mechanisms to protect the integrity of non-local maintenance and diagnostic communications.	0	0
APSC-DV-001950 - CAT II Applications used for non-local maintenance sessions must implement cryptographic mechanisms to protect the confidentiality of non-local maintenance and diagnostic communications.	0	0
APSC-DV-001960 - CAT II Applications used for non-local maintenance sessions must verify remote disconnection at the termination of non-local maintenance and diagnostic sessions.	0	0
APSC-DV-001970 - CAT II The application must employ strong authenticators in the establishment of non-local maintenance and diagnostic sessions.	0	0
APSC-DV-001980 - CAT II The application must terminate all sessions and network connections when non-local maintenance is completed.	0	0
APSC-DV-001995 - CAT II The application must not be vulnerable to race conditions.	0	0
APSC-DV-002000 - CAT II The application must terminate all network connections associated with a communications session at the end of the session.	0	0
APSC-DV-002010 - CAT II The application must implement NSA-approved cryptography to protect classified information in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, and standards.	0	0
APSC-DV-002020 - CAT II The application must utilize FIPS-validated cryptographic modules when signing application components.	0	0
APSC-DV-002030 - CAT II The application must utilize FIPS-validated cryptographic modules when generating cryptographic hashes.	0	0

APSC-DV-002040 - CAT II The application must utilize FIPS-validated cryptographic modules when protecting unclassified information that requires cryptographic protection.	0	0
APSC-DV-002150 - CAT II The application user interface must be either physically or logically separated from data storage and management interfaces.	0	0
APSC-DV-002210 - CAT II The application must set the HTTPOnly flag on session cookies.	0	0
APSC-DV-002220 - CAT II The application must set the secure flag on session cookies.	0	0
APSC-DV-002230 - CAT I The application must not expose session IDs.	0	0
APSC-DV-002240 - CAT I The application must destroy the session ID value and/or cookie on logoff or browser close.	0	0
APSC-DV-002250 - CAT II Applications must use system-generated session identifiers that protect against session fixation.	0	0
APSC-DV-002260 - CAT II Applications must validate session identifiers.	0	0
APSC-DV-002270 - CAT II Applications must not use URL embedded session IDs.	0	0
APSC-DV-002280 - CAT II The application must not re-use or recycle session IDs.	0	0
APSC-DV-002290 - CAT II The application must use the Federal Information Processing Standard (FIPS) 140-2-validated cryptographic modules and random number generator if the application implements encryption, key exchange, digital signature, and hash functionality.	0	0
APSC-DV-002300 - CAT II The application must only allow the use of DoD-approved certificate authorities for verification of the establishment of protected sessions.	0	0
APSC-DV-002310 - CAT I The application must fail to a secure state if system initialization fails, shutdown fails, or aborts fail.	0	0
APSC-DV-002320 - CAT II In the event of a system failure, applications must preserve any information necessary to determine cause of failure and any information necessary to return to operations with least disruption to mission processes.	0	0
APSC-DV-002330 - CAT II The application must protect the confidentiality and integrity of stored information when required by DoD policy or the information owner.	0	0
APSC-DV-002340 - CAT II The application must implement approved cryptographic mechanisms to prevent unauthorized modification of organization-defined information at rest on organization-defined information system components.	0	0
APSC-DV-002350 - CAT II The application must use appropriate cryptography in order to protect stored DoD information when required by the information owner or DoD policy.	0	0
APSC-DV-002360 - CAT II The application must isolate security functions from non-security functions.	0	0
APSC-DV-002370 - CAT II The application must maintain a separate execution domain for each executing process.	0	0
APSC-DV-002380 - CAT II Applications must prevent unauthorized and unintended information transfer via shared system resources.	0	0
APSC-DV-002390 - CAT II XML-based applications must mitigate DoS attacks by using XML filters, parser options, or gateways.	0	0
APSC-DV-002400 - CAT II The application must restrict the ability to launch Denial of Service (DoS) attacks against itself or other information systems.	0	0
APSC-DV-002410 - CAT II The web service design must include redundancy mechanisms when used with high-availability systems.	0	0
APSC-DV-002420 - CAT II An XML firewall function must be deployed to protect web services when exposed to untrusted networks.	0	0
APSC-DV-002610 - CAT II The application must remove organization-defined software components after updated versions have been installed.	0	0
APSC-DV-002440 - CAT I The application must protect the confidentiality and integrity of transmitted information.	0	0
APSC-DV-002450 - CAT II The application must implement cryptographic mechanisms to prevent unauthorized disclosure of information and/or detect changes to information during transmission unless otherwise protected by alternative physical safeguards, such as, at a minimum, a Prot	0	0

APSC-DV-002460 - CAT II The application must maintain the confidentiality and integrity of information during preparation for transmission.	0	0
APSC-DV-002470 - CAT II The application must maintain the confidentiality and integrity of information during reception.	0	0
APSC-DV-002480 - CAT II The application must not disclose unnecessary information to users.	0	0
APSC-DV-002485 - CAT I The application must not store sensitive information in hidden fields.	0	0
APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting (XSS) vulnerabilities.	0	0
APSC-DV-002500 - CAT II The application must protect from Cross-Site Request Forgery (CSRF) vulnerabilities.	0	0
APSC-DV-002510 - CAT I The application must protect from command injection.	0	0
APSC-DV-002520 - CAT II The application must protect from canonical representation vulnerabilities.	0	0
APSC-DV-002530 - CAT II The application must validate all input.	0	0
APSC-DV-002540 - CAT I The application must not be vulnerable to SQL Injection.	0	0
APSC-DV-002550 - CAT I The application must not be vulnerable to XML-oriented attacks.	0	0
APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.	0	0
APSC-DV-002570 - CAT II The application must generate error messages that provide information necessary for corrective actions without revealing information that could be exploited by adversaries.	0	0
APSC-DV-002580 - CAT II The application must reveal error messages only to the ISSO, ISSM, or SA.	0	0
APSC-DV-002590 - CAT I The application must not be vulnerable to overflow attacks.	0	0
APSC-DV-002630 - CAT II Security-relevant software updates and patches must be kept up to date.	0	0
APSC-DV-002760 - CAT II The application performing organization-defined security functions must verify correct operation of security functions.	0	0
APSC-DV-002900 - CAT II The ISSO must ensure application audit trails are retained for at least 1 year for applications without SAMI data, and 5 years for applications including SAMI data.	0	0
APSC-DV-002770 - CAT II The application must perform verification of the correct operation of security functions: upon system startup and/or restart; upon command by a user with privileged access; and/or every 30 days.	0	0
APSC-DV-002780 - CAT III The application must notify the ISSO and ISSM of failed security verification tests.	0	0
APSC-DV-002870 - CAT II Unsigned Category 1A mobile code must not be used in the application in accordance with DoD policy.	0	0
APSC-DV-002880 - CAT II The ISSO must ensure an account management process is implemented, verifying only authorized users can gain access to the application, and individual accounts designated as inactive, suspended, or terminated are promptly removed.	0	0
APSC-DV-002890 - CAT I Application web servers must be on a separate network segment from the application and database servers if it is a tiered application operating in the DoD DMZ.	0	0
APSC-DV-002910 - CAT II The ISSO must review audit trails periodically based on system documentation recommendations or immediately upon system security events.	0	0
APSC-DV-002920 - CAT II The ISSO must report all suspected violations of IA policies in accordance with DoD information system IA procedures.	0	0
APSC-DV-002930 - CAT II The ISSO must ensure active vulnerability testing is performed.	0	0
APSC-DV-002980 - CAT II New IP addresses, data services, and associated ports used by the application must be submitted to the appropriate approving authority for the organization, which in turn will be submitted through the DoD Ports, Protocols, and Services Management (DoD PPS	0	0
APSC-DV-002950 - CAT II Execution flow diagrams and design documents must be created to show how deadlock and recursion issues in web services are being mitigated.	0	0
APSC-DV-002960 - CAT II The designer must ensure the application does not store configuration and control files in the same directory as user data.	0	0
APSC-DV-002970 - CAT II The ISSO must ensure if a DoD STIG or NSA guide is not available, a third-party	0	0

product will be configured by following available guidance.		
APSC-DV-002990 - CAT II The application must be registered with the DoD Ports and Protocols Database.	0	0
APSC-DV-002990 - CAT II The application must be registered with the DoD Ports and Protocols Database.	0	0
APSC-DV-002995 - CAT II The Configuration Management (CM) repository must be properly patched and STIG compliant.	0	0
APSC-DV-003000 - CAT II Access privileges to the Configuration Management (CM) repository must be reviewed every three months.	0	0
APSC-DV-003010 - CAT II A Software Configuration Management (SCM) plan describing the configuration control and change management process of application objects developed by the organization and the roles and responsibilities of the organization must be created and maintained.	0	0
APSC-DV-003020 - CAT II A Configuration Control Board (CCB) that meets at least every release cycle, for managing the Configuration Management (CM) process must be established.	0	0
APSC-DV-003030 - CAT II The application services and interfaces must be compatible with and ready for IPv6 networks.	0	0
APSC-DV-003040 - CAT II The application must not be hosted on a general purpose machine if the application is designated as critical or high availability by the ISSO.	0	0
APSC-DV-003050 - CAT II A disaster recovery/continuity plan must exist in accordance with DoD policy based on the applications availability requirements.	0	0
APSC-DV-003060 - CAT II Recovery procedures and technical system features must exist so recovery is performed in a secure and verifiable manner. The ISSO will document circumstances inhibiting a trusted recovery.	0	0
APSC-DV-003070 - CAT II Data backup must be performed at required intervals in accordance with DoD policy.	0	0
APSC-DV-003080 - CAT II Back-up copies of the application software or source code must be stored in a fire-rated container or stored separately (offsite).	0	0
APSC-DV-003090 - CAT II Procedures must be in place to assure the appropriate physical and technical protection of the backup and restoration of the application.	0	0
APSC-DV-003100 - CAT II The application must use encryption to implement key exchange and authenticate endpoints prior to establishing a communication channel for key exchange.	0	0
APSC-DV-003110 - CAT I The application must not contain embedded authentication data.	0	0
APSC-DV-003120 - CAT I The application must have the capability to mark sensitive/classified output when required.	0	0
APSC-DV-003130 - CAT III Prior to each release of the application, updates to system, or applying patches; tests plans and procedures must be created and executed.	0	0
APSC-DV-003150 - CAT II At least one tester must be designated to test for security flaws in addition to functional testing.	0	0
APSC-DV-003140 - CAT II Application files must be cryptographically hashed prior to deploying to DoD operational networks.	0	0
APSC-DV-003160 - CAT III Test procedures must be created and at least annually executed to ensure system initialization, shutdown, and aborts are configured to verify the system remains in a secure state.	0	0
APSC-DV-003170 - CAT II An application code review must be performed on the application.	0	0
APSC-DV-003180 - CAT III Code coverage statistics must be maintained for each release of the application.	0	0
APSC-DV-003190 - CAT II Flaws found during a code review must be tracked in a defect tracking system.	0	0
APSC-DV-003200 - CAT II The changes to the application must be assessed for IA and accreditation impact prior to implementation.	0	0
APSC-DV-003210 - CAT II Security flaws must be fixed or addressed in the project plan.	0	0
APSC-DV-003215 - CAT III The application development team must follow a set of coding standards.	0	0
APSC-DV-003220 - CAT III The designer must create and update the Design Document for each release of the application.	0	0

APSC-DV-003230 - CAT II Threat models must be documented and reviewed for each application release and updated as required by design and functionality changes or when new threats are discovered.	0	0
APSC-DV-003235 - CAT II The application must not be subject to error handling vulnerabilities.	0	0
APSC-DV-003250 - CAT I The application must be decommissioned when maintenance or support is no longer available.	0	0
APSC-DV-003236 - CAT II The application development team must provide an application incident response plan.	0	0
APSC-DV-003240 - CAT I All products must be supported by the vendor or the development team.	0	0
APSC-DV-003260 - CAT III Procedures must be in place to notify users when an application is decommissioned.	0	0
APSC-DV-003270 - CAT II Unnecessary built-in application accounts must be disabled.	0	0
APSC-DV-003280 - CAT I Default passwords must be changed.	0	0
APSC-DV-003330 - CAT II The system must alert an administrator when low resource conditions are encountered.	0	0
APSC-DV-003285 - CAT II An Application Configuration Guide must be created and included with the application.	0	0
APSC-DV-003290 - CAT II If the application contains classified data, a Security Classification Guide must exist containing data elements and their classification.	0	0
APSC-DV-003300 - CAT II The designer must ensure uncategorized or emerging mobile code is not used in applications.	0	0
APSC-DV-003310 - CAT II Production database exports must have database administration credentials and sensitive data removed before releasing the export.	0	0
APSC-DV-003320 - CAT II Protections against DoS attacks must be implemented.	0	0
APSC-DV-003340 - CAT III At least one application administrator must be registered to receive update notifications, or security alerts, when automated alerts are available.	0	0
APSC-DV-003360 - CAT III The application must generate audit records when concurrent logons from different workstations occur.	0	0
APSC-DV-003345 - CAT III The application must provide notifications or alerts when product update and security related patches are available.	0	0
APSC-DV-003350 - CAT II Connections between the DoD enclave and the Internet or other public or commercial wide area networks must require a DMZ.	0	0
APSC-DV-003400 - CAT II The Program Manager must verify all levels of program management, designers, developers, and testers receive annual security training pertaining to their job function.	0	0
APSC-DV-000010 - CAT II The application must provide a capability to limit the number of logon sessions per user.	0	0
APSC-DV-000060 - CAT II The application must clear temporary storage and cookies when the session is terminated.	0	0
APSC-DV-000070 - CAT II The application must automatically terminate the non-privileged user session and log off non-privileged users after a 15 minute idle time period has elapsed.	0	0
APSC-DV-000080 - CAT II The application must automatically terminate the admin user session and log off admin users after a 10 minute idle time period is exceeded.	0	0
APSC-DV-000090 - CAT II Applications requiring user access authentication must provide a logoff capability for user initiated communication session.	0	0
APSC-DV-000100 - CAT III The application must display an explicit logoff message to users indicating the reliable termination of authenticated communications sessions.	0	0
APSC-DV-000110 - CAT II The application must associate organization-defined types of security attributes having organization-defined security attribute values with information in storage.	0	0
APSC-DV-000120 - CAT II The application must associate organization-defined types of security attributes having organization-defined security attribute values with information in process.	0	0
APSC-DV-000130 - CAT II The application must associate organization-defined types of security attributes	0	0

having organization-defined security attribute values with information in transmission.		
APSC-DV-000160 - CAT II The application must implement DoD-approved encryption to protect the confidentiality of remote access sessions.	0	0
APSC-DV-000170 - CAT II The application must implement cryptographic mechanisms to protect the integrity of remote access sessions.	0	0
APSC-DV-000190 - CAT I Messages protected with WS_Security must use time stamps with creation and expiration times.	0	0
APSC-DV-000180 - CAT II Applications with SOAP messages requiring integrity must include the following message elements:-Message ID-Service Request-Timestamp-SAML Assertion (optionally included in messages) and all elements of the message must be digitally signed.	0	0
APSC-DV-000200 - CAT I Validity periods must be verified on all application messages using WS-Security or SAML assertions.	0	0
APSC-DV-000210 - CAT II The application must ensure each unique asserting party provides unique assertion ID references for each SAML assertion.	0	0
APSC-DV-000220 - CAT II The application must ensure encrypted assertions, or equivalent confidentiality protections are used when assertion data is passed through an intermediary, and confidentiality of the assertion data is required when passing through the intermediary.	0	0
APSC-DV-000230 - CAT I The application must use the NotOnOrAfter condition when using the SubjectConfirmation element in a SAML assertion.	0	0
APSC-DV-000240 - CAT I The application must use both the NotBefore and NotOnOrAfter elements or OneTimeUse element when using the Conditions element in a SAML assertion.	0	0
APSC-DV-000250 - CAT II The application must ensure if a OneTimeUse element is used in an assertion, there is only one of the same used in the Conditions element portion of an assertion.	0	0
APSC-DV-000260 - CAT II The application must ensure messages are encrypted when the SessionIndex is tied to privacy data.	0	0
APSC-DV-000290 - CAT II Shared/group account credentials must be terminated when members leave the group.	0	0
APSC-DV-000280 - CAT II The application must provide automated mechanisms for supporting account management functions.	0	0
APSC-DV-000300 - CAT II The application must automatically remove or disable temporary user accounts 72 hours after account creation.	0	0
APSC-DV-000320 - CAT III The application must automatically disable accounts after a 35 day period of account inactivity.	0	0
APSC-DV-000330 - CAT II Unnecessary application accounts must be disabled, or deleted.	0	0
APSC-DV-000420 - CAT II The application must automatically audit account enabling actions.	0	0
APSC-DV-000340 - CAT II The application must automatically audit account creation.	0	0
APSC-DV-000350 - CAT II The application must automatically audit account modification.	0	0
APSC-DV-000360 - CAT II The application must automatically audit account disabling actions.	0	0
APSC-DV-000370 - CAT II The application must automatically audit account removal actions.	0	0
APSC-DV-000380 - CAT III The application must notify System Administrators and Information System Security Officers when accounts are created.	0	0
APSC-DV-000390 - CAT III The application must notify System Administrators and Information System Security Officers when accounts are modified.	0	0
APSC-DV-000400 - CAT III The application must notify System Administrators and Information System Security Officers of account disabling actions.	0	0
APSC-DV-000410 - CAT III The application must notify System Administrators and Information System Security Officers of account removal actions.	0	0
APSC-DV-000430 - CAT III The application must notify System Administrators and Information System Security Officers of account enabling actions.	0	0
APSC-DV-000440 - CAT II Application data protection requirements must be identified and documented.	0	0

APSC-DV-000520 - CAT II The application must audit the execution of privileged functions.	0	0
APSC-DV-000450 - CAT II The application must utilize organization-defined data mining detection techniques for organization-defined data storage objects to adequately detect data mining attempts.	0	0
APSC-DV-000460 - CAT I The application must enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.	0	0
APSC-DV-000470 - CAT II The application must enforce organization-defined discretionary access control policies over defined subjects and objects.	0	0
APSC-DV-000480 - CAT II The application must enforce approved authorizations for controlling the flow of information within the system based on organization-defined information flow control policies.	0	0
APSC-DV-000490 - CAT II The application must enforce approved authorizations for controlling the flow of information between interconnected systems based on organization-defined information flow control policies.	0	0
APSC-DV-000500 - CAT II The application must prevent non-privileged users from executing privileged functions to include disabling, circumventing, or altering implemented security safeguards/countermeasures.	0	0
APSC-DV-000510 - CAT I The application must execute without excessive account permissions.	0	0
APSC-DV-000530 - CAT I The application must enforce the limit of three consecutive invalid logon attempts by a user during a 15 minute time period.	0	0
APSC-DV-000560 - CAT III The application must retain the Standard Mandatory DoD Notice and Consent Banner on the screen until users acknowledge the usage conditions and take explicit actions to log on for further access.	0	0
APSC-DV-000540 - CAT II The application administrator must follow an approved process to unlock locked user accounts.	0	0
APSC-DV-000550 - CAT III The application must display the Standard Mandatory DoD Notice and Consent Banner before granting access to the application.	0	0
APSC-DV-000570 - CAT III The publicly accessible application must display the Standard Mandatory DoD Notice and Consent Banner before granting access to the application.	0	0
APSC-DV-000580 - CAT III The application must display the time and date of the users last successful logon.	0	0
APSC-DV-000630 - CAT II The application must provide audit record generation capability for the destruction of session IDs.	0	0
APSC-DV-000590 - CAT II The application must protect against an individual (or process acting on behalf of an individual) falsely denying having performed organization-defined actions to be covered by non-repudiation.	0	0
APSC-DV-000600 - CAT II For applications providing audit record aggregation, the application must compile audit records from organization-defined information system components into a system-wide audit trail that is time-correlated with an organization-defined level of tolerance	0	0
APSC-DV-000610 - CAT II The application must provide the capability for organization-identified individuals or roles to change the auditing to be performed on all application components, based on all selectable event criteria within organization-defined time thresholds.	0	0
APSC-DV-000620 - CAT II The application must provide audit record generation capability for the creation of session IDs.	0	0

掃描總結 - ASD STIG 5.3

Category	Issues Found	Best Fix Locations
APSC-DV-000640 - CAT II The application must provide audit record generation capability for the renewal of session IDs.	0	0
APSC-DV-000650 - CAT II The application must not write sensitive data into the application logs.	0	0
APSC-DV-000660 - CAT II The application must provide audit record generation capability for session timeouts.	0	0
APSC-DV-000670 - CAT II The application must record a time stamp indicating when the event occurred.	0	0
APSC-DV-000680 - CAT II The application must provide audit record generation capability for HTTP headers including User-Agent, Referer, GET, and POST.	0	0
APSC-DV-000690 - CAT II The application must provide audit record generation capability for connecting system IP addresses.	0	0
APSC-DV-000700 - CAT II The application must record the username or user ID of the user associated with the event.	0	0
APSC-DV-000710 - CAT II The application must generate audit records when successful/unsuccessful attempts to grant privileges occur.	0	0
APSC-DV-000720 - CAT II The application must generate audit records when successful/unsuccessful attempts to access security objects occur.	0	0
APSC-DV-000730 - CAT II The application must generate audit records when successful/unsuccessful attempts to access security levels occur.	0	0
APSC-DV-000740 - CAT II The application must generate audit records when successful/unsuccessful attempts to access categories of information (e.g., classification levels) occur.	0	0
APSC-DV-000750 - CAT II The application must generate audit records when successful/unsuccessful attempts to modify privileges occur.	0	0
APSC-DV-000760 - CAT II The application must generate audit records when successful/unsuccessful attempts to modify security objects occur.	0	0
APSC-DV-000770 - CAT II The application must generate audit records when successful/unsuccessful attempts to modify security levels occur.	0	0
APSC-DV-000780 - CAT II The application must generate audit records when successful/unsuccessful attempts to modify categories of information (e.g., classification levels) occur.	0	0
APSC-DV-000790 - CAT II The application must generate audit records when successful/unsuccessful attempts to delete privileges occur.	0	0
APSC-DV-000800 - CAT II The application must generate audit records when successful/unsuccessful attempts to delete security levels occur.	0	0
APSC-DV-000810 - CAT II The application must generate audit records when successful/unsuccessful attempts to delete application database security objects occur.	0	0
APSC-DV-000820 - CAT II The application must generate audit records when successful/unsuccessful attempts to delete categories of information (e.g., classification levels) occur.	0	0
APSC-DV-000830 - CAT II The application must generate audit records when successful/unsuccessful logon attempts occur.	0	0
APSC-DV-000840 - CAT II The application must generate audit records for privileged activities or other system-level access.	0	0
APSC-DV-000850 - CAT II The application must generate audit records showing starting and ending time for user access to the system.	0	0
APSC-DV-000860 - CAT II The application must generate audit records when successful/unsuccessful accesses to objects occur.	0	0

APSC-DV-000870 - CAT II The application must generate audit records for all direct access to the information system.	0	0
APSC-DV-000880 - CAT II The application must generate audit records for all account creations, modifications, disabling, and termination events.	0	0
APSC-DV-000910 - CAT II The application must initiate session auditing upon startup.	0	0
APSC-DV-000940 - CAT II The application must log application shutdown events.	0	0
APSC-DV-000950 - CAT II The application must log destination IP addresses.	0	0
APSC-DV-000960 - CAT II The application must log user actions involving access to data.	0	0
APSC-DV-000970 - CAT II The application must log user actions involving changes to data.	0	0
APSC-DV-000980 - CAT II The application must produce audit records containing information to establish when (date and time) the events occurred.	0	0
APSC-DV-000990 - CAT II The application must produce audit records containing enough information to establish which component, feature or function of the application triggered the audit event.	0	0
APSC-DV-001000 - CAT II When using centralized logging; the application must include a unique identifier in order to distinguish itself from other application logs.	0	0
APSC-DV-001010 - CAT II The application must produce audit records that contain information to establish the outcome of the events.	0	0
APSC-DV-001020 - CAT II The application must generate audit records containing information that establishes the identity of any individual or process associated with the event.	0	0
APSC-DV-001030 - CAT II The application must generate audit records containing the full-text recording of privileged commands or the individual identities of group account users.	0	0
APSC-DV-001040 - CAT II The application must implement transaction recovery logs when transaction based.	0	0
APSC-DV-001050 - CAT II The application must provide centralized management and configuration of the content to be captured in audit records generated by all application components.	0	0
APSC-DV-001070 - CAT II The application must off-load audit records onto a different system or media than the system being audited.	0	0
APSC-DV-001080 - CAT II The application must be configured to write application logs to a centralized log repository.	0	0
APSC-DV-001090 - CAT II The application must provide an immediate warning to the SA and ISSO (at a minimum) when allocated audit record storage volume reaches 75% of repository maximum audit record storage capacity.	0	0
APSC-DV-001100 - CAT II Applications categorized as having a moderate or high impact must provide an immediate real-time alert to the SA and ISSO (at a minimum) for all audit failure events.	0	0
APSC-DV-001110 - CAT II The application must alert the ISSO and SA (at a minimum) in the event of an audit processing failure.	0	0
APSC-DV-001120 - CAT II The application must shut down by default upon audit failure (unless availability is an overriding concern).	0	0
APSC-DV-001130 - CAT II The application must provide the capability to centrally review and analyze audit records from multiple components within the system.	0	0
APSC-DV-001140 - CAT II The application must provide the capability to filter audit records for events of interest based upon organization-defined criteria.	0	0
APSC-DV-001150 - CAT II The application must provide an audit reduction capability that supports on-demand reporting requirements.	0	0
APSC-DV-001160 - CAT II The application must provide an audit reduction capability that supports on-demand audit review and analysis.	0	0
APSC-DV-001170 - CAT II The application must provide an audit reduction capability that supports after-the-fact investigations of security incidents.	0	0
APSC-DV-001180 - CAT II The application must provide a report generation capability that supports on-demand audit review and analysis.	0	0

APSC-DV-001190 - CAT II The application must provide a report generation capability that supports on-demand reporting requirements.	0	0
APSC-DV-001200 - CAT II The application must provide a report generation capability that supports after-the-fact investigations of security incidents.	0	0
APSC-DV-001210 - CAT II The application must provide an audit reduction capability that does not alter original content or time ordering of audit records.	0	0
APSC-DV-001220 - CAT II The application must provide a report generation capability that does not alter original content or time ordering of audit records.	0	0
APSC-DV-001250 - CAT II The applications must use internal system clocks to generate time stamps for audit records.	0	0
APSC-DV-001260 - CAT II The application must record time stamps for audit records that can be mapped to Coordinated Universal Time (UTC) or Greenwich Mean Time (GMT).	0	0
APSC-DV-001270 - CAT II The application must record time stamps for audit records that meet a granularity of one second for a minimum degree of precision.	0	0
APSC-DV-001280 - CAT II The application must protect audit information from any type of unauthorized read access.	0	0
APSC-DV-001290 - CAT II The application must protect audit information from unauthorized modification.	0	0
APSC-DV-001300 - CAT II The application must protect audit information from unauthorized deletion.	0	0
APSC-DV-001310 - CAT II The application must protect audit tools from unauthorized access.	0	0
APSC-DV-001320 - CAT II The application must protect audit tools from unauthorized modification.	0	0
APSC-DV-001330 - CAT II The application must protect audit tools from unauthorized deletion.	0	0
APSC-DV-001340 - CAT II The application must back up audit records at least every seven days onto a different system or system component than the system or component being audited.	0	0
APSC-DV-001570 - CAT II The application must electronically verify Personal Identity Verification (PIV) credentials.	0	0
APSC-DV-001350 - CAT II The application must use cryptographic mechanisms to protect the integrity of audit information.	0	0
APSC-DV-001360 - CAT II Application audit tools must be cryptographically hashed.	0	0
APSC-DV-001370 - CAT II The integrity of the audit tools must be validated by checking the files for changes in the cryptographic hash value.	0	0
APSC-DV-001390 - CAT II The application must prohibit user installation of software without explicit privileged status.	0	0
APSC-DV-001410 - CAT II The application must enforce access restrictions associated with changes to application configuration.	0	0
APSC-DV-001420 - CAT II The application must audit who makes configuration changes to the application.	0	0
APSC-DV-001430 - CAT II The application must have the capability to prevent the installation of patches, service packs, or application components without verification the software component has been digitally signed using a certificate that is recognized and approved by the orga	0	0
APSC-DV-001440 - CAT II The applications must limit privileges to change the software resident within software libraries.	0	0
APSC-DV-001460 - CAT II An application vulnerability assessment must be conducted.	0	0
APSC-DV-001480 - CAT II The application must prevent program execution in accordance with organization-defined policies regarding software program usage and restrictions, and/or rules authorizing the terms and conditions of software program usage.	0	0
APSC-DV-001490 - CAT II The application must employ a deny-all, permit-by-exception (whitelist) policy to allow the execution of authorized software programs.	0	0
APSC-DV-001500 - CAT II The application must be configured to disable non-essential capabilities.	0	0
APSC-DV-001510 - CAT II The application must be configured to use only functions, ports, and protocols permitted to it in the PPSM CAL.	0	0

APSC-DV-001520 - CAT II The application must require users to reauthenticate when organization-defined circumstances or situations require reauthentication.	0	0
APSC-DV-001530 - CAT II The application must require devices to reauthenticate when organization-defined circumstances or situations requiring reauthentication.	0	0
APSC-DV-001540 - CAT I The application must uniquely identify and authenticate organizational users (or processes acting on behalf of organizational users).	0	0
APSC-DV-001550 - CAT II The application must use multifactor (Alt. Token) authentication for network access to privileged accounts.	0	0
APSC-DV-001560 - CAT II The application must accept Personal Identity Verification (PIV) credentials.	0	0
APSC-DV-001580 - CAT II The application must use multifactor (e.g., CAC, Alt. Token) authentication for network access to non-privileged accounts.	0	0
APSC-DV-001590 - CAT II The application must use multifactor (Alt. Token) authentication for local access to privileged accounts.	0	0
APSC-DV-001600 - CAT II The application must use multifactor (e.g., CAC, Alt. Token) authentication for local access to non-privileged accounts.	0	0
APSC-DV-001610 - CAT II The application must ensure users are authenticated with an individual authenticator prior to using a group authenticator.	0	0
APSC-DV-001620 - CAT II The application must implement replay-resistant authentication mechanisms for network access to privileged accounts.	0	0
APSC-DV-001630 - CAT II The application must implement replay-resistant authentication mechanisms for network access to non-privileged accounts.	0	0
APSC-DV-001640 - CAT II The application must utilize mutual authentication when endpoint device non-repudiation protections are required by DoD policy or by the data owner.	0	0
APSC-DV-001650 - CAT II The application must authenticate all network connected endpoint devices before establishing any connection.	0	0
APSC-DV-001660 - CAT II Service-Oriented Applications handling non-releasable data must authenticate endpoint devices via mutual SSL/TLS.	0	0
APSC-DV-001670 - CAT II The application must disable device identifiers after 35 days of inactivity unless a cryptographic certificate is used for authentication.	0	0
APSC-DV-001680 - CAT I The application must enforce a minimum 15-character password length.	0	0
APSC-DV-001690 - CAT II The application must enforce password complexity by requiring that at least one upper-case character be used.	0	0
APSC-DV-001700 - CAT II The application must enforce password complexity by requiring that at least one lower-case character be used.	0	0
APSC-DV-001710 - CAT II The application must enforce password complexity by requiring that at least one numeric character be used.	0	0
APSC-DV-001720 - CAT II The application must enforce password complexity by requiring that at least one special character be used.	0	0
APSC-DV-001730 - CAT II The application must require the change of at least 8 of the total number of characters when passwords are changed.	0	0
APSC-DV-001740 - CAT I The application must only store cryptographic representations of passwords.	0	0
APSC-DV-001850 - CAT I The application must not display passwords/PINs as clear text.	0	0
APSC-DV-001750 - CAT I The application must transmit only cryptographically-protected passwords.	0	0
APSC-DV-001760 - CAT II The application must enforce 24 hours/1 day as the minimum password lifetime.	0	0
APSC-DV-001770 - CAT II The application must enforce a 60-day maximum password lifetime restriction.	0	0
APSC-DV-001780 - CAT II The application must prohibit password reuse for a minimum of five generations.	0	0
APSC-DV-001790 - CAT II The application must allow the use of a temporary password for system logons with an immediate change to a permanent password.	0	0

APSC-DV-001795 - CAT II The application password must not be changeable by users other than the administrator or the user with which the password is associated.	0	0
APSC-DV-001800 - CAT II The application must terminate existing user sessions upon account deletion.	0	0
APSC-DV-001820 - CAT I The application, when using PKI-based authentication, must enforce authorized access to the corresponding private key.	0	0
APSC-DV-001830 - CAT II The application must map the authenticated identity to the individual user or group account for PKI-based authentication.	0	0
APSC-DV-001870 - CAT II The application must uniquely identify and authenticate non-organizational users (or processes acting on behalf of non-organizational users).	0	0
APSC-DV-001810 - CAT I The application, when utilizing PKI-based authentication, must validate certificates by constructing a certification path (which includes status information) to an accepted trust anchor.	0	0
APSC-DV-001840 - CAT II The application, for PKI-based authentication, must implement a local cache of revocation data to support path discovery and validation in case of the inability to access revocation information via the network.	0	0
APSC-DV-001860 - CAT II The application must use mechanisms meeting the requirements of applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance for authentication to a cryptographic module.	0	0
APSC-DV-001880 - CAT II The application must accept Personal Identity Verification (PIV) credentials from other federal agencies.	0	0
APSC-DV-001890 - CAT II The application must electronically verify Personal Identity Verification (PIV) credentials from other federal agencies.	0	0
APSC-DV-002050 - CAT II Applications making SAML assertions must use FIPS-approved random numbers in the generation of SessionIndex in the SAML element AuthnStatement.	0	0
APSC-DV-001900 - CAT II The application must accept FICAM-approved third-party credentials.	0	0
APSC-DV-001910 - CAT II The application must conform to FICAM-issued profiles.	0	0
APSC-DV-001930 - CAT II Applications used for non-local maintenance sessions must audit non-local maintenance and diagnostic sessions for organization-defined auditable events.	0	0
APSC-DV-000310 - CAT III The application must have a process, feature or function that prevents removal or disabling of emergency accounts.	0	0
APSC-DV-001940 - CAT II Applications used for non-local maintenance sessions must implement cryptographic mechanisms to protect the integrity of non-local maintenance and diagnostic communications.	0	0
APSC-DV-001950 - CAT II Applications used for non-local maintenance sessions must implement cryptographic mechanisms to protect the confidentiality of non-local maintenance and diagnostic communications.	0	0
APSC-DV-001960 - CAT II Applications used for non-local maintenance sessions must verify remote disconnection at the termination of non-local maintenance and diagnostic sessions.	0	0
APSC-DV-001970 - CAT II The application must employ strong authenticators in the establishment of non-local maintenance and diagnostic sessions.	0	0
APSC-DV-001980 - CAT II The application must terminate all sessions and network connections when non-local maintenance is completed.	0	0
APSC-DV-001995 - CAT II The application must not be vulnerable to race conditions.	0	0
APSC-DV-002000 - CAT II The application must terminate all network connections associated with a communications session at the end of the session.	0	0
APSC-DV-002010 - CAT II The application must implement NSA-approved cryptography to protect classified information in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, and standards.	0	0
APSC-DV-002020 - CAT II The application must utilize FIPS-validated cryptographic modules when signing application components.	0	0
APSC-DV-002030 - CAT II The application must utilize FIPS-validated cryptographic modules when generating cryptographic hashes.	0	0

APSC-DV-002040 - CAT II The application must utilize FIPS-validated cryptographic modules when protecting unclassified information that requires cryptographic protection.	0	0
APSC-DV-002150 - CAT II The application user interface must be either physically or logically separated from data storage and management interfaces.	0	0
APSC-DV-002210 - CAT II The application must set the HTTPOnly flag on session cookies.*	0	0
APSC-DV-002220 - CAT II The application must set the secure flag on session cookies.	0	0
APSC-DV-002230 - CAT I The application must not expose session IDs.*	0	0
APSC-DV-002240 - CAT I The application must destroy the session ID value and/or cookie on logoff or browser close.	0	0
APSC-DV-002250 - CAT II Applications must use system-generated session identifiers that protect against session fixation.	0	0
APSC-DV-002260 - CAT II Applications must validate session identifiers.	0	0
APSC-DV-002270 - CAT II Applications must not use URL embedded session IDs.	0	0
APSC-DV-002280 - CAT II The application must not re-use or recycle session IDs.	0	0
APSC-DV-002290 - CAT II The application must use the Federal Information Processing Standard (FIPS) 140-2-validated cryptographic modules and random number generator if the application implements encryption, key exchange, digital signature, and hash functionality.	0	0
APSC-DV-002300 - CAT II The application must only allow the use of DoD-approved certificate authorities for verification of the establishment of protected sessions.	0	0
APSC-DV-002310 - CAT I The application must fail to a secure state if system initialization fails, shutdown fails, or aborts fail.	0	0
APSC-DV-002320 - CAT II In the event of a system failure, applications must preserve any information necessary to determine cause of failure and any information necessary to return to operations with least disruption to mission processes.	0	0
APSC-DV-002330 - CAT II The application must protect the confidentiality and integrity of stored information when required by DoD policy or the information owner.	0	0
APSC-DV-002340 - CAT II The application must implement approved cryptographic mechanisms to prevent unauthorized modification of organization-defined information at rest on organization-defined information system components.	0	0
APSC-DV-002350 - CAT II The application must use appropriate cryptography in order to protect stored DoD information when required by the information owner or DoD policy.	0	0
APSC-DV-002360 - CAT II The application must isolate security functions from non-security functions.	0	0
APSC-DV-002370 - CAT II The application must maintain a separate execution domain for each executing process.	0	0
APSC-DV-002380 - CAT II Applications must prevent unauthorized and unintended information transfer via shared system resources.	0	0
APSC-DV-002390 - CAT II XML-based applications must mitigate DoS attacks by using XML filters, parser options, or gateways.	0	0
APSC-DV-002400 - CAT II The application must restrict the ability to launch Denial of Service (DoS) attacks against itself or other information systems.	0	0
APSC-DV-002410 - CAT II The web service design must include redundancy mechanisms when used with high-availability systems.	0	0
APSC-DV-002420 - CAT II An XML firewall function must be deployed to protect web services when exposed to untrusted networks.	0	0
APSC-DV-002610 - CAT II The application must remove organization-defined software components after updated versions have been installed.	0	0
APSC-DV-002440 - CAT I The application must protect the confidentiality and integrity of transmitted information.	0	0
APSC-DV-002450 - CAT II The application must implement cryptographic mechanisms to prevent unauthorized disclosure of information and/or detect changes to information during transmission unless otherwise protected by alternative physical safeguards, such as, at a minimum, a Prot	0	0

APSC-DV-002460 - CAT II The application must maintain the confidentiality and integrity of information during preparation for transmission.	0	0
APSC-DV-002470 - CAT II The application must maintain the confidentiality and integrity of information during reception.	0	0
APSC-DV-002480 - CAT II The application must not disclose unnecessary information to users.	0	0
APSC-DV-002485 - CAT I The application must not store sensitive information in hidden fields.	0	0
APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting (XSS) vulnerabilities.	0	0
APSC-DV-002500 - CAT II The application must protect from Cross-Site Request Forgery (CSRF) vulnerabilities.	0	0
APSC-DV-002510 - CAT I The application must protect from command injection.	0	0
APSC-DV-002520 - CAT II The application must protect from canonical representation vulnerabilities.	0	0
APSC-DV-002530 - CAT II The application must validate all input.	0	0
APSC-DV-002540 - CAT I The application must not be vulnerable to SQL Injection.*	0	0
APSC-DV-002550 - CAT I The application must not be vulnerable to XML-oriented attacks.	0	0
APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.*	0	0
APSC-DV-002570 - CAT II The application must generate error messages that provide information necessary for corrective actions without revealing information that could be exploited by adversaries.*	24	24
APSC-DV-002580 - CAT II The application must reveal error messages only to the ISSO, ISSM, or SA.	0	0
APSC-DV-002590 - CAT I The application must not be vulnerable to overflow attacks.	0	0
APSC-DV-002630 - CAT II Security-relevant software updates and patches must be kept up to date.	0	0
APSC-DV-002760 - CAT II The application performing organization-defined security functions must verify correct operation of security functions.	0	0
APSC-DV-002900 - CAT II The ISSO must ensure application audit trails are retained for at least 1 year for applications without SAMI data, and 5 years for applications including SAMI data.	0	0
APSC-DV-002770 - CAT II The application must perform verification of the correct operation of security functions: upon system startup and/or restart; upon command by a user with privileged access; and/or every 30 days.	0	0
APSC-DV-002780 - CAT III The application must notify the ISSO and ISSM of failed security verification tests.	0	0
APSC-DV-002870 - CAT II Unsigned Category 1A mobile code must not be used in the application in accordance with DoD policy.	0	0
APSC-DV-002880 - CAT II The ISSO must ensure an account management process is implemented, verifying only authorized users can gain access to the application, and individual accounts designated as inactive, suspended, or terminated are promptly removed.	0	0
APSC-DV-002890 - CAT I Application web servers must be on a separate network segment from the application and database servers if it is a tiered application operating in the DoD DMZ.	0	0
APSC-DV-002910 - CAT II The ISSO must review audit trails periodically based on system documentation recommendations or immediately upon system security events.	0	0
APSC-DV-002920 - CAT II The ISSO must report all suspected violations of IA policies in accordance with DoD information system IA procedures.	0	0
APSC-DV-002930 - CAT II The ISSO must ensure active vulnerability testing is performed.	0	0
APSC-DV-002980 - CAT II New IP addresses, data services, and associated ports used by the application must be submitted to the appropriate approving authority for the organization, which in turn will be submitted through the DoD Ports, Protocols, and Services Management (DoD PPS	0	0
APSC-DV-002950 - CAT II Execution flow diagrams and design documents must be created to show how deadlock and recursion issues in web services are being mitigated.	0	0
APSC-DV-002960 - CAT II The designer must ensure the application does not store configuration and control files in the same directory as user data.	0	0
APSC-DV-002970 - CAT II The ISSO must ensure if a DoD STIG or NSA guide is not available, a third-party	0	0

product will be configured by following available guidance.		
APSC-DV-002990 - CAT II The application must be registered with the DoD Ports and Protocols Database.	0	0
APSC-DV-002995 - CAT II The Configuration Management (CM) repository must be properly patched and STIG compliant.	0	0
APSC-DV-003000 - CAT II Access privileges to the Configuration Management (CM) repository must be reviewed every three months.	0	0
APSC-DV-003010 - CAT II A Software Configuration Management (SCM) plan describing the configuration control and change management process of application objects developed by the organization and the roles and responsibilities of the organization must be created and maintained.	0	0
APSC-DV-003020 - CAT II A Configuration Control Board (CCB) that meets at least every release cycle, for managing the Configuration Management (CM) process must be established.	0	0
APSC-DV-003030 - CAT II The application services and interfaces must be compatible with and ready for IPv6 networks.	0	0
APSC-DV-003040 - CAT II The application must not be hosted on a general purpose machine if the application is designated as critical or high availability by the ISSO.	0	0
APSC-DV-003050 - CAT II A disaster recovery/continuity plan must exist in accordance with DoD policy based on the applications availability requirements.	0	0
APSC-DV-003060 - CAT II Recovery procedures and technical system features must exist so recovery is performed in a secure and verifiable manner. The ISSO will document circumstances inhibiting a trusted recovery.	0	0
APSC-DV-003070 - CAT II Data backup must be performed at required intervals in accordance with DoD policy.	0	0
APSC-DV-003080 - CAT II Back-up copies of the application software or source code must be stored in a fire-rated container or stored separately (offsite).	0	0
APSC-DV-003090 - CAT II Procedures must be in place to assure the appropriate physical and technical protection of the backup and restoration of the application.	0	0
APSC-DV-003100 - CAT II The application must use encryption to implement key exchange and authenticate endpoints prior to establishing a communication channel for key exchange.	0	0
APSC-DV-003110 - CAT I The application must not contain embedded authentication data.	0	0
APSC-DV-003120 - CAT I The application must have the capability to mark sensitive/classified output when required.	0	0
APSC-DV-003130 - CAT III Prior to each release of the application, updates to system, or applying patches; tests plans and procedures must be created and executed.	0	0
APSC-DV-003150 - CAT II At least one tester must be designated to test for security flaws in addition to functional testing.	0	0
APSC-DV-003140 - CAT II Application files must be cryptographically hashed prior to deploying to DoD operational networks.	0	0
APSC-DV-003160 - CAT III Test procedures must be created and at least annually executed to ensure system initialization, shutdown, and aborts are configured to verify the system remains in a secure state.	0	0
APSC-DV-003170 - CAT II An application code review must be performed on the application.	0	0
APSC-DV-003180 - CAT III Code coverage statistics must be maintained for each release of the application.	0	0
APSC-DV-003190 - CAT II Flaws found during a code review must be tracked in a defect tracking system.	0	0
APSC-DV-003200 - CAT II The changes to the application must be assessed for IA and accreditation impact prior to implementation.	0	0
APSC-DV-003210 - CAT II Security flaws must be fixed or addressed in the project plan.	0	0
APSC-DV-003215 - CAT III The application development team must follow a set of coding standards.	0	0
APSC-DV-003220 - CAT III The designer must create and update the Design Document for each release of the application.	0	0
APSC-DV-003230 - CAT II Threat models must be documented and reviewed for each application release	0	0

and updated as required by design and functionality changes or when new threats are discovered.		
APSC-DV-003235 - CAT II The application must not be subject to error handling vulnerabilities.*	0	0
APSC-DV-003250 - CAT I The application must be decommissioned when maintenance or support is no longer available.	0	0
APSC-DV-003236 - CAT II The application development team must provide an application incident response plan.	0	0
APSC-DV-003240 - CAT I All products must be supported by the vendor or the development team.	0	0
APSC-DV-003260 - CAT III Procedures must be in place to notify users when an application is decommissioned.	0	0
APSC-DV-003270 - CAT II Unnecessary built-in application accounts must be disabled.	0	0
APSC-DV-003280 - CAT I Default passwords must be changed.	0	0
APSC-DV-003330 - CAT II The system must alert an administrator when low resource conditions are encountered.	0	0
APSC-DV-003285 - CAT II An Application Configuration Guide must be created and included with the application.	0	0
APSC-DV-003290 - CAT II If the application contains classified data, a Security Classification Guide must exist containing data elements and their classification.	0	0
APSC-DV-003300 - CAT II The designer must ensure uncategorized or emerging mobile code is not used in applications.	0	0
APSC-DV-003310 - CAT II Production database exports must have database administration credentials and sensitive data removed before releasing the export.	0	0
APSC-DV-003320 - CAT II Protections against DoS attacks must be implemented.	0	0
APSC-DV-003340 - CAT III At least one application administrator must be registered to receive update notifications, or security alerts, when automated alerts are available.	0	0
APSC-DV-003360 - CAT III The application must generate audit records when concurrent logons from different workstations occur.	0	0
APSC-DV-003345 - CAT III The application must provide notifications or alerts when product update and security related patches are available.	0	0
APSC-DV-003350 - CAT II Connections between the DoD enclave and the Internet or other public or commercial wide area networks must require a DMZ.	0	0
APSC-DV-003400 - CAT II The Program Manager must verify all levels of program management, designers, developers, and testers receive annual security training pertaining to their job function.	0	0
APSC-DV-000010 - CAT II The application must provide a capability to limit the number of logon sessions per user.	0	0
APSC-DV-000060 - CAT II The application must clear temporary storage and cookies when the session is terminated.	0	0
APSC-DV-000070 - CAT II The application must automatically terminate the non-privileged user session and log off non-privileged users after a 15 minute idle time period has elapsed.	0	0
APSC-DV-000080 - CAT II The application must automatically terminate the admin user session and log off admin users after a 10 minute idle time period is exceeded.	0	0
APSC-DV-000090 - CAT II Applications requiring user access authentication must provide a logoff capability for user initiated communication session.	0	0
APSC-DV-000100 - CAT III The application must display an explicit logoff message to users indicating the reliable termination of authenticated communications sessions.	0	0
APSC-DV-000110 - CAT II The application must associate organization-defined types of security attributes having organization-defined security attribute values with information in storage.	0	0
APSC-DV-000120 - CAT II The application must associate organization-defined types of security attributes having organization-defined security attribute values with information in process.	0	0
APSC-DV-000130 - CAT II The application must associate organization-defined types of security attributes having organization-defined security attribute values with information in transmission.	0	0

APSC-DV-000160 - CAT II The application must implement DoD-approved encryption to protect the confidentiality of remote access sessions.	0	0
APSC-DV-000170 - CAT II The application must implement cryptographic mechanisms to protect the integrity of remote access sessions.	0	0
APSC-DV-000190 - CAT I Messages protected with WS_Security must use time stamps with creation and expiration times.	0	0
APSC-DV-000180 - CAT II Applications with SOAP messages requiring integrity must include the following message elements:-Message ID-Service Request-Timestamp-SAML Assertion (optionally included in messages) and all elements of the message must be digitally signed.	0	0
APSC-DV-000200 - CAT I Validity periods must be verified on all application messages using WS-Security or SAML assertions.	0	0
APSC-DV-000210 - CAT II The application must ensure each unique asserting party provides unique assertion ID references for each SAML assertion.	0	0
APSC-DV-000220 - CAT II The application must ensure encrypted assertions, or equivalent confidentiality protections are used when assertion data is passed through an intermediary, and confidentiality of the assertion data is required when passing through the intermediary.	0	0
APSC-DV-000230 - CAT I The application must use the NotOnOrAfter condition when using the SubjectConfirmation element in a SAML assertion.	0	0
APSC-DV-000240 - CAT I The application must use both the NotBefore and NotOnOrAfter elements or OneTimeUse element when using the Conditions element in a SAML assertion.	0	0
APSC-DV-000250 - CAT II The application must ensure if a OneTimeUse element is used in an assertion, there is only one of the same used in the Conditions element portion of an assertion.	0	0
APSC-DV-000260 - CAT II The application must ensure messages are encrypted when the SessionIndex is tied to privacy data.	0	0
APSC-DV-000290 - CAT II Shared/group account credentials must be terminated when members leave the group.	0	0
APSC-DV-000280 - CAT II The application must provide automated mechanisms for supporting account management functions.	0	0
APSC-DV-000300 - CAT II The application must automatically remove or disable temporary user accounts 72 hours after account creation.	0	0
APSC-DV-000320 - CAT III The application must automatically disable accounts after a 35 day period of account inactivity.	0	0
APSC-DV-000330 - CAT II Unnecessary application accounts must be disabled, or deleted.	0	0
APSC-DV-000420 - CAT II The application must automatically audit account enabling actions.	0	0
APSC-DV-000340 - CAT II The application must automatically audit account creation.	0	0
APSC-DV-000350 - CAT II The application must automatically audit account modification.	0	0
APSC-DV-000360 - CAT II The application must automatically audit account disabling actions.	0	0
APSC-DV-000370 - CAT II The application must automatically audit account removal actions.	0	0
APSC-DV-000380 - CAT III The application must notify System Administrators and Information System Security Officers when accounts are created.	0	0
APSC-DV-000390 - CAT III The application must notify System Administrators and Information System Security Officers when accounts are modified.	0	0
APSC-DV-000400 - CAT III The application must notify System Administrators and Information System Security Officers of account disabling actions.	0	0
APSC-DV-000410 - CAT III The application must notify System Administrators and Information System Security Officers of account removal actions.	0	0
APSC-DV-000430 - CAT III The application must notify System Administrators and Information System Security Officers of account enabling actions.	0	0
APSC-DV-000440 - CAT II Application data protection requirements must be identified and documented.	0	0
APSC-DV-000520 - CAT II The application must audit the execution of privileged functions.	0	0

APSC-DV-000450 - CAT II The application must utilize organization-defined data mining detection techniques for organization-defined data storage objects to adequately detect data mining attempts.	0	0
APSC-DV-000460 - CAT I The application must enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.*	0	0
APSC-DV-000470 - CAT II The application must enforce organization-defined discretionary access control policies over defined subjects and objects.*	0	0
APSC-DV-000480 - CAT II The application must enforce approved authorizations for controlling the flow of information within the system based on organization-defined information flow control policies.	0	0
APSC-DV-000490 - CAT II The application must enforce approved authorizations for controlling the flow of information between interconnected systems based on organization-defined information flow control policies.	0	0
APSC-DV-000500 - CAT II The application must prevent non-privileged users from executing privileged functions to include disabling, circumventing, or altering implemented security safeguards/countermeasures.	0	0
APSC-DV-000510 - CAT I The application must execute without excessive account permissions.	0	0
APSC-DV-000530 - CAT I The application must enforce the limit of three consecutive invalid logon attempts by a user during a 15 minute time period.	0	0
APSC-DV-000560 - CAT III The application must retain the Standard Mandatory DoD Notice and Consent Banner on the screen until users acknowledge the usage conditions and take explicit actions to log on for further access.	0	0
APSC-DV-000540 - CAT II The application administrator must follow an approved process to unlock locked user accounts.	0	0
APSC-DV-000550 - CAT III The application must display the Standard Mandatory DoD Notice and Consent Banner before granting access to the application.	0	0
APSC-DV-000570 - CAT III The publicly accessible application must display the Standard Mandatory DoD Notice and Consent Banner before granting access to the application.	0	0
APSC-DV-000580 - CAT III The application must display the time and date of the users last successful logon.	0	0
APSC-DV-000630 - CAT II The application must provide audit record generation capability for the destruction of session IDs.	0	0
APSC-DV-000590 - CAT II The application must protect against an individual (or process acting on behalf of an individual) falsely denying having performed organization-defined actions to be covered by non-repudiation.	0	0
APSC-DV-000600 - CAT II For applications providing audit record aggregation, the application must compile audit records from organization-defined information system components into a system-wide audit trail that is time-correlated with an organization-defined level of tolerance	0	0
APSC-DV-000610 - CAT II The application must provide the capability for organization-identified individuals or roles to change the auditing to be performed on all application components, based on all selectable event criteria within organization-defined time thresholds.	0	0
APSC-DV-000620 - CAT II The application must provide audit record generation capability for the creation of session IDs.	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - OWASP Top 10 2010

Category	Issues Found	Best Fix Locations
A1-Injection	0	0
A2-Cross-Site Scripting (XSS)	0	0
A3-Broken Authentication and Session Management*	0	0
A4-Insecure Direct Object References	0	0
A5-Cross-Site Request Forgery (CSRF)	0	0
A6-Security Misconfiguration	0	0
A7-Insecure Cryptographic Storage	0	0
A8-Failure to Restrict URL Access	0	0
A9-Insufficient Transport Layer Protection	0	0
A10-Unvalidated Redirects and Forwards	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - OWASP Top 10 API 2023

Category	Issues Found	Best Fix Locations
API1-Broken Object Level Authorization	0	0
API2-Broken Authentication	0	0
API3-Broken Object Property Level Authorization*	4	4
API4-Unrestricted Resource Consumption	0	0
API5-Broken Function Level Authorization	0	0
API6-Unrestricted Access to Sensitive Business Flows	0	0
API7-Server Side Request Forgery	0	0
API8-Security Misconfiguration*	13	13
API9-Improper Inventory Management	0	0
API10-Unsafe Consumption of APIs	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - MOIS(KISA) Secure Coding 2021

Category	Issues Found	Best Fix Locations
MOIS(KISA) API misuse*	0	0
MOIS(KISA) Code error*	0	0
MOIS(KISA) Encapsulation*	0	0
MOIS(KISA) Error processing*	24	24
MOIS(KISA) Security Functions*	7	5
MOIS(KISA) Time and status*	0	0
MOIS(KISA) Verification and representation of input data*	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - SANS top 25

Category	Issues Found	Best Fix Locations
SANS top 25*	3	3

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - CWE top 25

Category	Issues Found	Best Fix Locations
CWE top 25*	3	3

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - Top Tier

Category	Issues Found	Best Fix Locations
Top Tier	0	0

掃描總結 - OWASP ASVS

Category	Issues Found	Best Fix Locations
V01 Architecture, Design and Threat Modeling*	0	0
V02 Authentication*	0	0
V03 Session Management*	4	4
V04 Access Control	2	2
V05 Validation, Sanitization and Encoding*	0	0
V06 Stored Cryptography*	0	0
V07 Error Handling and Logging*	209	209
V08 Data Protection*	0	0
V09 Communication*	5	3
V10 Malicious Code	0	0
V11 Business Logic*	0	0
V12 Files and Resources*	0	0
V13 API and Web Service	0	0
V14 Configuration*	35	35

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - ASA Mobile Premium

Category	Issues Found	Best Fix Locations
ASA Mobile Premium*	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - ASA Premium

Category	Issues Found	Best Fix Locations
ASA Premium*	0	0

* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描總結 - Base Preset

Category	Issues Found	Best Fix Locations
Base Preset*	0	0

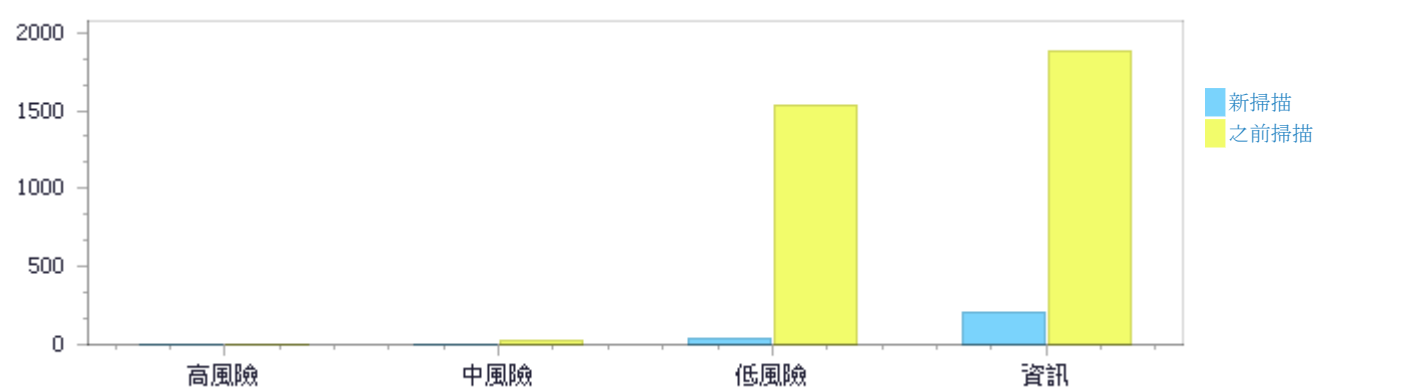
* 專案掃描結果不包括所有相關的查詢。應該變更預設和/或篩選器以包括所有相關的標準查詢。

掃描結果分佈

與2026/5/11 上午 10:17的專案掃描比較

	高風險	中風險	低風險	資訊	總共
新問題	0	0	1	0	1
反覆出現的問題	0	4	42	209	255
總共	0	4	43	209	256

已修復的問題	0	22	1,491	1,676	3,189
--------	---	----	-------	-------	-------



掃描結果分佈

	高風險	中風險	低風險	資訊	總共
校驗	0	4	43	209	256
不可利用	0	0	0	0	0
確認	0	0	0	0	0
緊急	0	0	0	0	0
推薦不可用	0	0	0	0	0
總共	0	4	43	209	256

掃描結果摘要

漏洞類別	事件	嚴重程度：
Excessive Data Exposure	4	中風險
Improper Exception Handling	23	低風險
Spring Overly Permissive Cross Origin Resource Sharing Policy	10	低風險
Serializable Class Containing Sensitive Data	5	低風險
Incorrect Permission Assignment For Critical Resources	2	低風險

Information Exposure Through an Error Message	1	低風險
Portability Flaw Locale Dependent Comparison	1	低風險
Spring Missing Content Security Policy	1	低風險
Insufficient Logging of Exceptions	209	資訊

10個最容易受攻擊的檔案

高級和中級漏洞

檔案名稱	找到的問題
uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java	4

掃描結果詳細資料

Excessive Data Exposure

查詢路徑:

Java\Cx\Java Medium Threat\Excessive Data Exposure 版本:6

類別

OWASP ASVS: V03 Session Management

OWASP Top 10 2021: A1-Broken Access Control

OWASP Top 10 API 2023: API3-Broken Object Property Level Authorization

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

描述

Excessive Data Exposure\路徑 1:

嚴重程度：	中風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=1
狀態	反覆出現的問題
Detection Date	5/11/2026 11:19:31 AM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 的第 39 行中的 arg 內的資料可能是敏感的。通過位於 uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 的第 39 行中的arg 中的 API 來暴露上述敏感資訊。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
行	39	39
物件	arg	arg

代碼片斷

檔案名稱	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
方法	<pre> public ApiResponse<ServiceRs<BadDebtEntryRs>> createBadDebtEntry(@RequestBody ApiResponse<ServiceRq<BadDebtEntryRq>> apiRequest) { 39. return ApiResponseBuilder.success(badDebtEntryService.createBadDebtEntry(arg)); </pre>

Excessive Data Exposure\路徑 2:

嚴重程度：	中風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=1

狀態	id=2 反覆出現的問題
Detection Date	5/11/2026 11:19:31 AM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 的第 46 行中的 arg 內的資料可能是敏感的。通過位於 uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 的第 46 行中的arg 中的 API 來暴露上述敏感資訊。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
行	46	46
物件	arg	arg

代碼片斷
檔案名稱

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java

方法
public ApiResponse<ServiceRs<BadDebtEntryRs>> queryBadDebtEntry(@RequestBody ApiRequest<ServiceRq<BadDebtEntryQueryRq>> apiRequest) {

```
....
46.    return
    ApiResponseBuilder.success(badDebtEntryService.queryBadDebtEntry(arg));
```

Excessive Data Exposure\路徑 3:

嚴重程度：	中風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=3
狀態	反覆出現的問題
Detection Date	5/11/2026 11:19:31 AM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 的第 53 行中的 arg 內的資料可能是敏感的。通過位於 uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 的第 53 行中的arg 中的 API 來暴露上述敏感資訊。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
行	53	53
物件	arg	arg

代碼片斷

檔案名稱 uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java

方法 public ApiResponse<ServiceRs<BadDebtEntryRs>> updateBadDebtEntry(@RequestBody ApiRequest<ServiceRq<BadDebtEntryRq>> apiRequest) {

```

.....
53.    return
ApiResponseBuilder.success(badDebtEntryService.updateBadDebtEntry(arg));

```

Excessive Data Exposure\路徑 4:

嚴重程度： 中風險

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=4>

狀態 反覆出現的問題

Detection Date 5/11/2026 11:19:31 AM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 的第 60 行中的 arg 內的資料可能是敏感的。通過位於 uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 的第 60 行中的arg 中的 API 來暴露上述敏感資訊。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
行	60	60
物件	arg	arg

代碼片斷

檔案名稱 uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java

方法 public ApiResponse<ServiceRs<BadDebtEntryRs>> deleteBadDebtEntry(@RequestBody ApiRequest<ServiceRq<BadDebtEntryQueryRq>> apiRequest) {

```

.....
60.    return
ApiResponseBuilder.success(badDebtEntryService.deleteBadDebtEntry(arg));

```

Improper Exception Handling

查詢路徑:

Java\Cx\Java Low Visibility\Improper Exception Handling 版本:1

類別

PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.5 - Improper error handling

NIST SP 800-53: SC-5 Denial of Service Protection (P1)

MOIS(KISA) Secure Coding 2021: MOIS(KISA) Error processing

OWASP ASVS: V14 Configuration

OWASP Top 10 2021: A4-Insecure Design

ASD STIG 5.3: APSC-DV-002570 - CAT II The application must generate error messages that provide information necessary for corrective actions without revealing information that could be exploited by adversaries.

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

描述

Improper Exception Handling\路徑 1:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=5
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法getFinInvoicesByMonth在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcicTa1Tasklet.java第355 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcicTa1Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcicTa1Tasklet.java
行	355	355
物件	findByCreatedTimestamp	findByCreatedTimestamp

代碼片斷

檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcicTa1Tasklet.java
方法	private List<LenFinancingInvoiceEntity> getFinInvoicesByMonth(LocalDate date) { <pre> 355. return financingInvoiceRepository.findByCreatedTimestamp(startDate, endDate); </pre>

Improper Exception Handling\路徑 2:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=6
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法getBadDebtWriteOffDate在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java第499 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java

行	499	499
物件	findByAaAccountDetailsId	findByAaAccountDetailsId

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java

方法

private LocalDate getBadDebtWriteOffDate(String arrangementId) {

```

.....
499.  MvMidAaAccountDetailsEntity aaAccountDetails =
Optional.ofNullable(aaAccountDetailsRepository.findByAaAccountDetailsId(
arrangementId))

```

Improper Exception Handling\路徑 3:

嚴重程度：低風險

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=7>

狀態：反覆出現的問題

Detection Date 5/11/2026 11:21:01 AM

方法findAllDelAccounts在uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/t24view/MvMidAaAccountDetailsStatusRepository.java第100行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/t24view/MvMidAaAccountDetailsStatusRepository.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/t24view/MvMidAaAccountDetailsStatusRepository.java
行	100	100
物件	findAllByAgeAllStatusAndAgeAllDateBetween	findAllByAgeAllStatusAndAgeAllDateBetween

代碼片斷

檔案名稱

uatFiles/len/len-

service/src/main/java/com/scsb/ncbs/len/persistence/repository/t24view/MvMidAaAccountDetailsStatusRepository.java

方法

default List<MvMidAaAccountDetailsStatusEntity> findAllDelAccounts() {

```

.....
100. return findAllByAgeAllStatusAndAgeAllDateBetween("DEL",
oneMonthAgo, now);

```

Improper Exception Handling\路徑 4:

嚴重程度：低風險

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=7>

狀態	id=8 反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法getBadDebtWriteOffDate在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java第508 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java
行	508	508
物件	findByAaAccountDetailsIdAndAgeAllStatus	findByAaAccountDetailsIdAndAgeAllStatus

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java

方法

private LocalDate getBadDebtWriteOffDate(String arrangementId) {

```

.....
508.    return
Optional.ofNullable(aaAccountDetailsStatusRepository.findByAaAccountDetailsIdAndAgeAllStatus(arrangementId, "BCY"))

```

Improper Exception Handling\路徑 5:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=9
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法buildBodyC在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java第730 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java
行	730	730
物件	readByIdComp1OrderByAaArrLimitIdDesc	readByIdComp1OrderByAaArrLimitIdDesc

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java

方法	private Jcic204BodyBean buildBodyC(MvMidEbContractBalancesEntity ebcBalances, MvMidLimitEntity limit) { 730. MvMidAaArrLimitEntity aaArrLimit = aaArrLimitRepository.readByIdComp1OrderByAaArrLimitIdDesc (aaArrangement. getAaArrangementId()).stream() }
----	---

Improper Exception Handling\路徑 6:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=10
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法buildBodyD在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java第798 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java
行	798	798
物件	readByIdComp1OrderByAaArrLimitIdDesc	readByIdComp1OrderByAaArrLimitIdDesc

代碼片斷

檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java
方法	private Jcic204BodyBean buildBodyD(MvMidEbContractBalancesEntity ebcBalances, MvMidLimitEntity limit) { 798. MvMidAaArrLimitEntity aaArrLimit = aaArrLimitRepository.readByIdComp1OrderByAaArrLimitIdDesc (aaArrangement. getAaArrangementId()).stream() }

Improper Exception Handling\路徑 7:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=11
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法buildBodyE在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java第861 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java
行	861	861
物件	readByIdComp1OrderByAaArrLimitIdDesc	readByIdComp1OrderByAaArrLimitIdDesc

代碼片斷
檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java

方法

private Jcic204BodyBean buildBodyE(MvMidEbContractBalancesEntity ebcBalances, MvMidLimitEntity limit) {

```
....
861. MvMidAaArrLimitEntity aaArrLimit =
aaArrLimitRepository.readByIdComp1OrderByAaArrLimitIdDesc(aaArrangement.
getAaArrangementId()).stream()
```

Improper Exception Handling\路徑 8:

嚴重程度： 低風險

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=12>

狀態 反覆出現的問題

Detection Date 5/11/2026 11:21:01 AM

方法retrieveAaArrOverdue在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic902Tasklet.java第366 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic902Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic902Tasklet.java
行	366	366
物件	readByIdComp1OrderByAaArrOverdueldDesc	readByIdComp1OrderByAaArrOverdueldDesc

代碼片斷
檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic902Tasklet.java

方法

private MvMidAaArrOverdueEntity retrieveAaArrOverdue(String arrangementId) {

```
....
366. Optional<MvMidAaArrOverdueEntity> mvAaBillDetailsEntity =
aaArrOverdueRepository.readByIdComp1OrderByAaArrOverdueIdDesc(arrangemen
tId).stream()
```

Improper Exception Handling\路徑 9:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=13
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法getRepaymentRecord在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java第444 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java
行	444	444
物件	findByArrangementIdAndAgingStatus	findByArrangementIdAndAgingStatus

代碼片斷

檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic211Tasklet.java
方法	private String getRepaymentRecord(String txAttribute, String arrangementId) {
	<pre> 444. MvMidAaBillDetailsEntity aaBillDetails = aaBillDetailsRepository.findByArrangementIdAndAgingStatus(arrangementId, "DEL").stream() </pre>

Improper Exception Handling\路徑 10:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=14
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法getCustomer在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/trading/CreditAlertTasklet.java第493 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/trading/CreditAlertTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/trading/CreditAlertTasklet.java
行	493	493
物件	findByCustomerId	findByCustomerId

代碼片斷

檔案名稱	uatFiles/len/len-
方法	bat/src/main/java/com/scsb/ncbs/len/batch/job/trading/CreditAlertTasklet.java private MvMidCustomerEntity getCustomer(String customerId) { 493. Optional<MvMidCustomerEntity> customer = Optional.ofNullable(mvMidCustomerRepository.findById(customerId));

Improper Exception Handling\路徑 11:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=15
狀態	反覆出現的問題
Detection Date	9/22/2025 6:04:50 PM

方法getDataWrapper在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java第1105 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	1105	1105
物件	findForJcic201	findForJcic201

代碼片斷	
檔案名稱	uatFiles/len/len-
方法	bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java private Jcic201DataWrapper getDataWrapper(MvMidAaArrangementEntity arrangement) { 1105. dataWrapper.setTotalCurrAssets(ebContractBalancesCurrAssetRepository.findForJcic201(dataWrapper.getEbContractBalances().getEbContractBalancesId()));

Improper Exception Handling\路徑 12:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=16
狀態	反覆出現的問題
Detection Date	9/22/2025 6:04:50 PM

方法getDataWrapper在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java第766 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java
行	766	766
物件	findForJcic201	findForJcic201

代碼片斷
檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java

方法 private Jcic201DataWrapper getDataWrapper(MvMidAaArrangementEntity arrangement) {

```
.....
766.
dataWrapper.setTotalCurrAssets(ebContractBalancesCurrAssetRepository.find
dForJcic201(dataWrapper.getEbContractBalances().getEbContractBalancesId(
))) ;
```

Improper Exception Handling\路徑 13:

嚴重程度： 低風險

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=17>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:04:50 PM

方法getDataWrapper在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java第1107 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	1107	1107
物件	findBalanceAssetForJcic201	findBalanceAssetForJcic201

代碼片斷
檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法 private Jcic201DataWrapper getDataWrapper(MvMidAaArrangementEntity arrangement) {

```
.....
1107.
dataWrapper.setBalanceCurrAssets(ebContractBalancesCurrAssetRepository.f
indBalanceAssetForJcic201(arrangement.getLinkedApplId())) ;
```

Improper Exception Handling\路徑 14:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=18
狀態	反覆出現的問題
Detection Date	9/22/2025 6:04:50 PM

方法getDataWrapper在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java第768 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java
行	768	768
物件	findBalanceAssetForJcic201	findBalanceAssetForJcic201

代碼片斷

檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java
方法	private Jcic201DataWrapper getDataWrapper(MvMidAaArrangementEntity arrangement) {
	<pre> 768. dataWrapper.setBalanceCurrAssets(ebContractBalancesCurrAssetRepository.findBalanceAssetForJcic201(arrangement.getLinkedApplId())); </pre>

Improper Exception Handling\路徑 15:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=19
狀態	反覆出現的問題
Detection Date	9/22/2025 6:04:50 PM

方法getDataWrapper在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java第1109 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	1109	1109
物件	findDelinquentAssetForJcic201	findDelinquentAssetForJcic201

代碼片斷

檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法 private Jcic201DataWrapper getDataWrapper(MvMidAaArrangementEntity arrangement) {

```

.....
1109.
dataWrapper.setDelinquentCurrAssets(ebContractBalancesCurrAssetRepository.findDelinquentAssetForJcic201(arrangement.getLinkedApplId()));

```

Improper Exception Handling\路徑 16:

嚴重程度： 低風險

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=20>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:04:50 PM

方法getDataWrapper在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java第770 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java
行	770	770
物件	findDelinquentAssetForJcic201	findDelinquentAssetForJcic201

代碼片斷

檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java

方法 private Jcic201DataWrapper getDataWrapper(MvMidAaArrangementEntity arrangement) {

```

.....
770.
dataWrapper.setDelinquentCurrAssets(ebContractBalancesCurrAssetRepository.findDelinquentAssetForJcic201(arrangement.getLinkedApplId()));

```

Improper Exception Handling\路徑 17:

嚴重程度： 低風險

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=21>

狀態 反覆出現的問題

Detection Date 5/11/2026 11:21:01 AM

方法getDataWrapper在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java第1103 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	1103	1103
物件	findByEbContractBalancesId	findByEbContractBalancesId

代碼片斷
檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法 private Jcic201DataWrapper getDataWrapper(MvMidAaArrangementEntity arrangement) {

```

.....
1103.
dataWrapper.setEbContractBalances(ebContractBalancesRepository.findByEbContractBalancesId(arrangement.getLinkedApplId()));

```

Improper Exception Handling\路徑 18:

嚴重程度： 低風險

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=22>

狀態 反覆出現的問題

Detection Date 5/11/2026 11:21:01 AM

方法getDataWrapper在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java第764 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java
行	764	764
物件	findByEbContractBalancesId	findByEbContractBalancesId

代碼片斷
檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java

方法 private Jcic201DataWrapper getDataWrapper(MvMidAaArrangementEntity arrangement) {

```

.....
764.
dataWrapper.setEbContractBalances(ebContractBalancesRepository.findByEbContractBalancesId(arrangement.getLinkedApplId()));

```

Improper Exception Handling\路徑 19:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=23
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法getDataWrapper在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201DTasklet.java第546 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201DTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201DTasklet.java
行	546	546
物件	findByEbContractBalancesId	findByEbContractBalancesId

代碼片斷
檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201DTasklet.java

方法
private Jcic201DataWrapper getDataWrapper(MvMidMdDealEntity mdDeal, MvMidLimitEntity limit) {

```

.....
546.
dataWrapper.setEbContractBalances(ebContractBalancesRepository.findByEbContractBalancesId(mdDeal.getMdDealId()));

```

Improper Exception Handling\路徑 20:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=24
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法.map在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java第603 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java
行	603	603
物件	findByEbContractBalancesId	findByEbContractBalancesId

代碼片斷

檔案名稱	uatFiles/len/len-
方法	bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java .map(limitAccount -> ebContractBalancesRepository.findByEbContractBalancesId(limitAccount.getAccount()))
	<pre> 603. .map(limitAccount -> ebContractBalancesRepository.findByEbContractBalancesId(limitAccount.getAccount())) </pre>

Improper Exception Handling\路徑 21:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=25
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法prepareGRMBodyData在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcicGRMTasklet.java第180 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcicGRMTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcicGRMTasklet.java
行	180	180
物件	findForJcicGRM	findForJcicGRM

代碼片斷	
檔案名稱	uatFiles/len/len-
方法	bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcicGRMTasklet.java private List<JcicGRMBodyBean> prepareGRMBodyData() {
	<pre> 180. List<String> customerIds = ebContractBalancesRepository.findForJcicGRM().stream() </pre>

Improper Exception Handling\路徑 22:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=26
狀態	反覆出現的問題
Detection Date	5/11/2026 11:21:01 AM

方法buildBodyA在uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java第602 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java
行	602	602
物件	readByLimitId	readByLimitId

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic204Tasklet.java

方法

private Jcic204BodyBean buildBodyA(MvMidLimitEntity limit) {

```
.....
602.    BigDecimal workingBalanceTwdSum =
limitAccountRepository.readByLimitId(limit.getLimitId()).stream()
```

Improper Exception Handling\路徑 23:

嚴重程度：低風險

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=27>

狀態：反覆出現的問題

Detection Date 9/22/2025 6:04:50 PM

方法doProcess在uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java第110 行執行可預期拋出異常的操作，但未正確包裹在try-catch區塊中。這構成不當異常處理(Improper Exception Handling)。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java
行	110	110
物件	findLimitsFor080	findLimitsFor080

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java

方法

private void doProcess() {

```
.....
110.    dataWrapper.setLimits(limitRepository.findLimitsFor080());
```

Spring Overly Permissive Cross Origin Resource Sharing Policy

查詢路徑:

Java\Cx\Java Spring\Spring Overly Permissive Cross Origin Resource Sharing Policy 版本:2

類別

OWASP ASVS: V14 Configuration

OWASP Top 10 2021: A7-Identification and Authentication Failures

OWASP Top 10 API 2023: API8-Security Misconfiguration

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

描述

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 1:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=38
狀態	反覆出現的問題
Detection Date	9/22/2025 6:07:39 PM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java 文件第 46 行上的 readBondInfo 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java
行	46	46
物件	readBondInfo	readBondInfo

代碼片斷

檔案名稱	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java
方法	public ApiResponse<ServiceRs<BondInfoRs>> readBondInfo(@RequestBody ApiRequest<ServiceRq<BondInfoRq>> apiRequest) { <pre> 46. public ApiResponse<ServiceRs<BondInfoRs>> readBondInfo (@RequestBody ApiRequest<ServiceRq<BondInfoRq>> apiRequest) { </pre>

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 2:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=39
狀態	反覆出現的問題
Detection Date	9/22/2025 6:07:39 PM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java 文件第 53 行上的 readBondLoan 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller

	er/collatertal/BondCollateralController.java	er/collatertal/BondCollateralController.java
行	53	53
物件	readBondLoan	readBondLoan

代碼片斷
檔案名稱

uatFiles/len/len-

方法

app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java

```
public ApiResponse<ServiceRs<BondLoanRs>> readBondLoan(@RequestBody
ApiRequest<ServiceRq<BondLoanRq>> apiRequest) {
```

```
....
53. public ApiResponse<ServiceRs<BondLoanRs>> readBondLoan(@RequestBody
ApiRequest<ServiceRq<BondLoanRq>> apiRequest) {
```

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 3:

嚴重程度：低風險

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=40>

狀態：反覆出現的問題

Detection Date 9/22/2025 6:07:39 PM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java 文件第 60 行上的 maintainBondLoan 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java
行	60	60
物件	maintainBondLoan	maintainBondLoan

代碼片斷
檔案名稱

uatFiles/len/len-

方法

app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java

```
public ApiResponse<ServiceRs<BondLoanRs>> maintainBondLoan(@RequestBody
ApiRequest<ServiceRq<BondLoanRq>> apiRequest) {
```

```
....
60. public ApiResponse<ServiceRs<BondLoanRs>>
maintainBondLoan(@RequestBody ApiRequest<ServiceRq<BondLoanRq>>
apiRequest) {
```

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 4:

嚴重程度：低風險

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=41>

狀態 反覆出現的問題
Detection Date 4/24/2026 7:03:22 PM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java 文件第 68 行上的 readSnBondInfo 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java
行	68	68
物件	readSnBondInfo	readSnBondInfo

代碼片斷
檔案名稱

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java

方法

```
public ApiResponse<ServiceRs<SnBondInfoRs>> readSnBondInfo(@RequestBody
    ApiRequest<ServiceRq<SnBondInfoRq>> apiRequest) {
```

```
....
68. public ApiResponse<ServiceRs<SnBondInfoRs>>
    readSnBondInfo(@RequestBody ApiRequest<ServiceRq<SnBondInfoRq>>
        apiRequest) {
```

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 5:

嚴重程度： 低風險
結果狀態： 校驗
線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=42>
狀態 反覆出現的問題
Detection Date 4/24/2026 7:03:22 PM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java 文件第 75 行上的 readSnBondLoan 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java
行	75	75
物件	readSnBondLoan	readSnBondLoan

代碼片斷
檔案名稱

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java

方法

```
public ApiResponse<ServiceRs<SnBondLoanRs>> readSnBondLoan(@RequestBody
    ApiRequest<ServiceRq<SnBondLoanRq>> apiRequest) {
```

```

.....
75. public ApiResponse<ServiceRs<SnBondLoanRs>>
readSnBondLoan(@RequestBody ApiRequest<ServiceRq<SnBondLoanRq>>
apiRequest) {

```

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 6:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=43
狀態	反覆出現的問題
Detection Date	4/24/2026 7:03:22 PM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java 文件第 82 行上的 maintainSnBondLoan 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java
行	82	82
物件	maintainSnBondLoan	maintainSnBondLoan

代碼片斷
檔案名稱

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/collatertal/BondCollateralController.java

方法

```

public ApiResponse<ServiceRs<SnBondLoanRs>> maintainSnBondLoan(@RequestBody
ApiRequest<ServiceRq<SnBondLoanRq>> apiRequest) {

```

```

.....
82. public ApiResponse<ServiceRs<SnBondLoanRs>>
maintainSnBondLoan(@RequestBody ApiRequest<ServiceRq<SnBondLoanRq>>
apiRequest) {

```

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 7:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=44
狀態	反覆出現的問題
Detection Date	5/11/2026 11:23:59 AM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 文件第 37 行上的 createBadDebtEntry 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller

	er/debt/BadDebtEntryController.java	er/debt/BadDebtEntryController.java
行	37	37
物件	createBadDebtEntry	createBadDebtEntry

代碼片斷
檔案名稱

uatFiles/len/len-

方法

app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java

```
public ApiResponse<ServiceRs<BadDebtEntryRs>> createBadDebtEntry(@RequestBody
ApiRequest<ServiceRq<BadDebtEntryRq>> apiRequest) {
```

```
....
37. public ApiResponse<ServiceRs<BadDebtEntryRs>>
createBadDebtEntry(@RequestBody ApiRequest<ServiceRq<BadDebtEntryRq>>
apiRequest) {
```

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 8:

嚴重程度：低風險

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=45>

狀態 反覆出現的問題

Detection Date 5/11/2026 11:23:59 AM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 文件第 44 行上的 queryBadDebtEntry 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
行	44	44
物件	queryBadDebtEntry	queryBadDebtEntry

代碼片斷
檔案名稱

uatFiles/len/len-

方法

app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java

```
public ApiResponse<ServiceRs<BadDebtEntryRs>> queryBadDebtEntry(@RequestBody
ApiRequest<ServiceRq<BadDebtEntryQueryRq>> apiRequest) {
```

```
....
44. public ApiResponse<ServiceRs<BadDebtEntryRs>>
queryBadDebtEntry(@RequestBody
ApiRequest<ServiceRq<BadDebtEntryQueryRq>> apiRequest) {
```

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 9:

嚴重程度：低風險

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=45>

狀態 [id=46](#)
反覆出現的問題
Detection Date 5/11/2026 11:23:59 AM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 文件第 51 行上的 updateBadDebtEntry 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
行	51	51
物件	updateBadDebtEntry	updateBadDebtEntry

代碼片斷
檔案名稱

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
方法
public ApiResponse<ServiceRs<BadDebtEntryRs>> updateBadDebtEntry(@RequestBody ApiRequest<ServiceRq<BadDebtEntryRq>> apiRequest) {

```
....
51. public ApiResponse<ServiceRs<BadDebtEntryRs>>
updateBadDebtEntry(@RequestBody ApiRequest<ServiceRq<BadDebtEntryRq>>
apiRequest) {
```

Spring Overly Permissive Cross Origin Resource Sharing Policy\路徑 10:

嚴重程度： 低風險
結果狀態： 校驗
線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=47>
狀態 反覆出現的問題
Detection Date 5/11/2026 11:23:59 AM

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java 文件第 58 行上的 deleteBadDebtEntry 方法設置了過度寬鬆的 CORS 訪問控制來源標頭。

	來源	目的地
檔案	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java	uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
行	58	58
物件	deleteBadDebtEntry	deleteBadDebtEntry

代碼片斷
檔案名稱

uatFiles/len/len-app/src/main/java/com/scsb/ncbs/len/controller/debt/BadDebtEntryController.java
方法
public ApiResponse<ServiceRs<BadDebtEntryRs>> deleteBadDebtEntry(@RequestBody ApiRequest<ServiceRq<BadDebtEntryQueryRq>> apiRequest) {


```

.....
58. public ApiResponse<ServiceRs<BadDebtEntryRs>>
deleteBadDebtEntry (@RequestBody
ApiRequest<ServiceRq<BadDebtEntryQueryRq>> apiRequest) {

```

Serializable Class Containing Sensitive Data

查詢路徑:

Java\Cx\Java Low Visibility\Serializable Class Containing Sensitive Data 版本:5

類別

OWASP Top 10 2013: A6-Sensitive Data Exposure
OWASP Top 10 2017: A3-Sensitive Data Exposure
MOIS(KISA) Secure Coding 2021: MOIS(KISA) Security Functions
OWASP ASVS: V09 Communication
OWASP Top 10 2021: A4-Insecure Design
PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

描述

Serializable Class Containing Sensitive Data\路徑 1:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=32
狀態	反覆出現的問題
Detection Date	9/22/2025 6:06:37 PM

敏感資訊的欄位 creditAcctNo 在 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java 的第 34 行，被插入到可序列化物件 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java 的第 15 行中的 MvMidFundsTransferEntity 欄位。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
行	34	15
物件	creditAcctNo	MvMidFundsTransferEntity

代碼片斷

檔案名稱	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
方法	private String creditAcctNo;

```

.....
34. private String creditAcctNo;

```

檔案名稱	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
方法	@Data
	<pre> 15. @Data </pre>

Serializable Class Containing Sensitive Data\路徑 2:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=33
狀態	反覆出現的問題
Detection Date	9/22/2025 6:06:37 PM

敏感資訊的欄位 creditValueDate 在 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java 的第 38 行，被插入到可序列化物件 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java 的第 15 行中的 MvMidFundsTransferEntity 欄位。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
行	38	15
物件	creditValueDate	MvMidFundsTransferEntity

代碼片斷	
檔案名稱	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
方法	private LocalDate creditValueDate;
	<pre> 38. private LocalDate creditValueDate; </pre>

檔案名稱	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
方法	@Data

```
.....
15.  @Data
```

Serializable Class Containing Sensitive Data\路徑 3:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=34
狀態	反覆出現的問題
Detection Date	9/22/2025 6:06:37 PM

敏感資訊的欄位 amountCredited 在 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java 的第 56 行，被插入到可序列化物件 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java 的第 15 行中的 MvMidFundsTransferEntity 欄位。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
行	56	15
物件	amountCredited	MvMidFundsTransferEntity

代碼片斷

檔案名稱	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
方法	private String amountCredited;

```
.....
56.  private String amountCredited;
```

檔案名稱	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidFundsTransferEntity.java
方法	@Data

```
.....
15.  @Data
```

Serializable Class Containing Sensitive Data\路徑 4:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=34

[id=35](#)

狀態 反覆出現的問題
 Detection Date 9/22/2025 6:06:37 PM

敏感資訊的欄位 letterOfCreditId 在 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidLetterOfCreditEntity.java 的第 22 行，被插入到可序列化物件 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidLetterOfCreditEntity.java 的第 16 行中的 MvMidLetterOfCreditEntity 欄位。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidLetterOfCreditEntity.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidLetterOfCreditEntity.java
行	22	16
物件	letterOfCreditId	MvMidLetterOfCreditEntity

代碼片斷

檔案名稱 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidLetterOfCreditEntity.java

方法 private String letterOfCreditId;

```
....
22. private String letterOfCreditId;
```

檔案名稱 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidLetterOfCreditEntity.java

方法 @Data

```
....
16. @Data
```

Serializable Class Containing Sensitive Data\路徑 5:

嚴重程度： 低風險
 結果狀態： 校驗
 線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=36>
 狀態 反覆出現的問題
 Detection Date 9/22/2025 6:06:37 PM

敏感資訊的欄位 accountNumber 在 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidStmtEntryEntity.java 的第 25 行，被插入到可序列化物件 uatFiles/len/len-

service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidStmntEntryEntity.java 的第 16 行中的 MvMidStmntEntryEntity 欄位。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidStmntEntryEntity.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidStmntEntryEntity.java
行	25	16
物件	accountNumber	MvMidStmntEntryEntity

代碼片斷

檔案名稱

uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidStmntEntryEntity.java

方法

private String accountNumber;

```
....
25. private String accountNumber;
```

檔案名稱

uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/entity/t24view/MvMidStmntEntryEntity.java

方法

@Data

```
....
16. @Data
```

Incorrect Permission Assignment For Critical Resources

查詢路徑:

Java\Cx\Java Low Visibility\Incorrect Permission Assignment For Critical Resources 版本:6

類別

FISMA 2014: Access Control

NIST SP 800-53: AC-3 Access Enforcement (P1)

OWASP Top 10 2017: A6-Security Misconfiguration

CWE top 25: CWE top 25

MOIS(KISA) Secure Coding 2021: MOIS(KISA) Security Functions

OWASP ASVS: V04 Access Control

OWASP Top 10 2021: A4-Insecure Design

SANS top 25: SANS top 25

OWASP Top 10 API 2023: API8-Security Misconfiguration

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

[描述](#)

Incorrect Permission Assignment For Critical Resources\路徑 1:

嚴重程度： 低風險

結果狀態： 校驗

線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=29
狀態	反覆出現的問題
Detection Date	9/22/2025 6:05:08 PM

檔案系統中由 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/query/LenInterestDetailRepository.java 第 37 行的 interestStartPath 建立一個具有潛在危險權限的檔案。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/query/LenInterestDetailRepository.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/query/LenInterestDetailRepository.java
行	37	37
物件	interestStartPath	interestStartPath

代碼片斷	
檔案名稱	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/query/LenInterestDetailRepository.java
方法	Specification<LenInterestDetailEntity> spec = ((root, query, criteriaBuilder) -> { <pre> ... 37. Path<LocalDate> interestStartPath = root.get(LenInterestDetailEntity_.INTEREST_START_DATE); </pre>

Incorrect Permission Assignment For Critical Resources\路徑 2:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=30
狀態	反覆出現的問題
Detection Date	9/22/2025 6:05:08 PM

檔案系統中由 uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/query/LenInterestDetailRepository.java 第 38 行的 interestEndPath 建立一個具有潛在危險權限的檔案。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/query/LenInterestDetailRepository.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/query/LenInterestDetailRepository.java
行	38	38
物件	interestEndPath	interestEndPath

代碼片斷

檔案名稱	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/persistence/repository/query/LenInterestDetailRepository.java
方法	Specification<LenInterestDetailEntity> spec = ((root, query, criteriaBuilder) -> {

```

.....
38.    Path<LocalDate> interestEndPath =
root.get(LenInterestDetailEntity_.INTEREST_END_DATE);

```

Information Exposure Through an Error Message

查詢路徑:

Java\Cx\Java Low Visibility\Information Exposure Through an Error Message 版本:6

類別

PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.5 - Improper error handling
 OWASP Top 10 2013: A5-Security Misconfiguration
 FISMA 2014: Configuration Management
 NIST SP 800-53: SI-11 Error Handling (P2)
 OWASP Top 10 2017: A6-Security Misconfiguration
 OWASP Top 10 API: API3-Excessive Data Exposure
 CWE top 25: CWE top 25
 MOIS(KISA) Secure Coding 2021: MOIS(KISA) Error processing
 OWASP ASVS: V14 Configuration
 OWASP Top 10 2021: A4-Insecure Design
 SANS top 25: SANS top 25
 ASD STIG 5.3: APSC-DV-002570 - CAT II The application must generate error messages that provide information necessary for corrective actions without revealing information that could be exploited by adversaries.
 OWASP Top 10 API 2023: API8-Security Misconfiguration
 PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

描述

Information Exposure Through an Error Message\路徑 1:

嚴重程度：	低風險
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=28
狀態	反覆出現的問題
Detection Date	9/22/2025 6:05:08 PM

在 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java 第 349 行的 prepare080BodyData 方法處理了例外或執行錯誤 e。在例外處理期間，應用程式在 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java prepare080BodyData 方法中將例外詳細資訊 printStackTrace 揭露。

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java
行	349	350

物件	e	printStackTrace
----	---	-----------------

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java

方法

private List<Jcic080BodyBean> prepare080BodyData(Jcic080DataWrapper dataWrapper) {

```

.....
349.     catch (Exception e) {
350.         e.printStackTrace();

```

Portability Flaw Locale Dependent Comparison

查詢路徑:

Java\Cx\Java Low Visibility\Portability Flaw Locale Dependent Comparison 版本:4

[描述](#)**Portability Flaw Locale Dependent Comparison\路徑 1:**

嚴重程度：低風險

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=31>

狀態 反覆出現的問題

Detection Date 3/5/2026 10:19:50 AM

應用程式在處理字串時未指定特定語系。特別是在文件uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/service/query/PaymentCalculationService.java中的第312行的sumPropertiesMatch方法呼叫ToUpperCase時。這個字串經處理後的結果與文件uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/service/query/PaymentCalculationService.java中的第312行的sumPropertiesMatch方法的contains進行比較。

	來源	目的地
檔案	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/service/query/PaymentCalculationService.java	uatFiles/len/len-service/src/main/java/com/scsb/ncbs/len/service/query/PaymentCalculationService.java
行	312	312
物件	toUpperCase	contains

代碼片斷

檔案名稱

uatFiles/len/len-

service/src/main/java/com/scsb/ncbs/len/service/query/PaymentCalculationService.java

方法

BigDecimal feeTotal = sumPropertiesMatch(simulationLatestBody.getProperties(), prop -> prop.toUpperCase().contains("FEE"));

```

.....
312.     BigDecimal feeTotal =
sumPropertiesMatch(simulationLatestBody.getProperties(), prop ->
prop.toUpperCase().contains("FEE"));

```

Spring Missing Content Security Policy

查詢路徑:

Java\Cx\Java Spring\Spring Missing Content Security Policy 版本:4

類別

OWASP ASVS: V14 Configuration

OWASP Top 10 2021: A7-Identification and Authentication Failures

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

描述**Spring Missing Content Security Policy\路徑 1:**

嚴重程度：低風險

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=37>

狀態：新的

Detection Date 5/4/2026 3:27:23 PM

Web 應用程式中未明確定義內容安全性原則。

	來源	目的地
檔案	uatFiles/dep/dep-service/src/main/java/com/scsb/ncbs/dep/service/query/customer/QueryCustomer3515Service.java	uatFiles/dep/dep-service/src/main/java/com/scsb/ncbs/dep/service/query/customer/QueryCustomer3515Service.java
行	35	35
物件	annotation	annotation

代碼片斷

檔案名稱 uatFiles/dep/dep-service/src/main/java/com/scsb/ncbs/dep/service/query/customer/QueryCustomer3515Service.java

方法 import org.springframework.beans.factory.annotation.Autowired;

```
....
35. import org.springframework.beans.factory.annotation.Autowired;
```

Insufficient Logging of Exceptions

查詢路徑:

Java\Cx\Java Best Coding Practice\Insufficient Logging of Exceptions 版本:2

類別

OWASP ASVS: V07 Error Handling and Logging

OWASP Top 10 2021: A9-Security Logging and Monitoring Failures

描述**Insufficient Logging of Exceptions\路徑 1:**

嚴重程度：資訊

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=48>

狀態 反覆出現的問題
 Detection Date 9/22/2025 6:08:43 PM

In line 409, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	409	409
物件	catch	catch

代碼片斷
 檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
 方法 public String convertCategoryMemoFor201(MvMidLimitEntity limit, String aaArrangementId,

```

    ....
    409.     } catch (Exception e) {
  
```

Insufficient Logging of Exceptions\路徑 2:

嚴重程度： 資訊
 結果狀態： 校驗
 線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=49>
 狀態 反覆出現的問題
 Detection Date 9/22/2025 6:08:43 PM

In line 446, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	446	446
物件	catch	catch

代碼片斷
 檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
 方法 public String convertCategoryMemoFor080(MvMidLimitEntity limit) {

```

    ....
    446.     } catch (Exception e) {
  
```

Insufficient Logging of Exceptions\路徑 3:

嚴重程度： 資訊

結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=50
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 808, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	808	808
物件	catch	catch

代碼片斷	
檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
方法	public String getCollateralAmount(MvMidLimitEntity limit, String secured, String recordKey) {
	<pre> 808. } catch (Exception e) { </pre>

Insufficient Logging of Exceptions\路徑 4:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=51
狀態	反覆出現的問題
Detection Date	5/11/2026 11:26:00 AM

In line 829, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	829	829
物件	catch	catch

代碼片斷	
檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
方法	public BigDecimal convertToTwtdThousands(BigDecimal amount, String currency) {
	<pre> 829. catch (Exception e) { </pre>

Insufficient Logging of Exceptions\路徑 5:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=52
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 887, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	887	887
物件	catch	catch

代碼片斷

檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
 方法 public BigDecimal convertAmount(BigDecimal amount, String sourceCurrency, String targetCurrency) {

```
.....
887.    } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 6:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=53
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 972, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	972	972
物件	catch	catch

代碼片斷

檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java

方法 public void processLimitGuarsFor201(List<Jcic201BodyBean> result, Jcic201BodyBean bean, MvMidLimitEntity limit) {

```
.....
972.    } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 7:

嚴重程度： 資訊
 結果狀態： 校驗
 線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=54>
 狀態 反覆出現的問題
 Detection Date 9/22/2025 6:08:43 PM

In line 987, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	987	987
物件	catch	catch

代碼片斷
 檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
 方法 private Jcic201BodyBean cloneJcic201BodyBean(Jcic201BodyBean bean) {

```
.....
987.    } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 8:

嚴重程度： 資訊
 結果狀態： 校驗
 線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=55>
 狀態 反覆出現的問題
 Detection Date 9/22/2025 6:08:43 PM

In line 1182, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	1182	1182
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java

方法

public String getUsage(String lLiLoanPur) {

```

.....
1182.    } catch (Exception e) {

```

Insufficient Logging of Exceptions\路徑 9:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=56>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 1272, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	1272	1272
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java

方法

public boolean checkExistCollatCode(MvMidLimitEntity limit) {

```

.....
1272.    } catch (Exception e) {

```

Insufficient Logging of Exceptions\路徑 10:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=57>

狀態 反覆出現的問題

Detection Date 5/11/2026 11:26:00 AM

In line 1316, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java

行	1316	1316
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java

方法

public BigDecimal calCollateralValue(MvMidLimitEntity limit) {

```
.....
1316. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 11:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=58>

狀態 反覆出現的問題

Detection Date 5/11/2026 11:26:00 AM

In line 1340, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	1340	1340
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java

方法

public BigDecimal calTotalAmount(Jcic201BodyBean bean) {

```
.....
1340. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 12:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=59>

狀態 反覆出現的問題

Detection Date 5/11/2026 11:26:00 AM

In line 1427, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

來源	目的地
----	-----

檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	1427	1427
物件	catch	catch

代碼片斷
檔案名稱
方法

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
public void saveData(List<Jcic201BodyBean> beans) {

```
.....
1427.    catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 13:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=60
狀態	反覆出現的問題
Detection Date	5/11/2026 11:26:00 AM

In line 1482, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
行	1482	1482
物件	catch	catch

代碼片斷
檔案名稱
方法

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/helper/JcicHelper.java
public boolean excludeExportBill(MvMidLimitEntity limit) {

```
.....
1482.    } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 14:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=61
狀態	反覆出現的問題
Detection Date	12/19/2025 4:55:03 PM

In line 150, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java
行	150	150
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java

方法

private void doProcess() {

```
.....
150.    } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 15:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=62>

狀態 反覆出現的問題

Detection Date 12/19/2025 4:55:03 PM

In line 190, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java
行	190	190
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java

方法

private void doProcess() {

```
.....
190.    } catch (NumberFormatException e) {
```

Insufficient Logging of Exceptions\路徑 16:

嚴重程度：資訊

結果狀態：校驗

線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=63
狀態	反覆出現的問題
Detection Date	12/19/2025 4:55:03 PM

In line 294, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java
行	294	294
物件	catch	catch

代碼片斷	
檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java
方法	private BigDecimal calculateCustomerTotalCollateralValue(LenFundLoanEntity fundLoanEntity) { 294. } catch (NullPointerException e) {

Insufficient Logging of Exceptions\路徑 17:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=64
狀態	反覆出現的問題
Detection Date	5/11/2026 11:26:00 AM

In line 434, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java
行	434	434
物件	catch	catch

代碼片斷	
檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/CollateralRatioNotifyTasklet.java
方法	private void sendNotification(String custNo, String buType, LenFundLoanEntity fundLoanEntity, String totalOs,

```
.....
434.    } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 18:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=65
狀態	反覆出現的問題
Detection Date	12/19/2025 4:55:03 PM

In line 183, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java
行	183	183
物件	catch	catch

代碼片斷

檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java

方法 private List<BondInfoInputDTO> parseFileToDto(StepContribution contribution) {

```
.....
183.    } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 19:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=66
狀態	反覆出現的問題
Detection Date	12/19/2025 4:55:03 PM

In line 216, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java
行	216	216
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java

方法

private RemoteFileItemReader<BondInfoInputDTO> reader() {

```

    ....
    216. } catch (Exception e) {

```

Insufficient Logging of Exceptions\路徑 20:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=67>

狀態 反覆出現的問題

Detection Date 12/19/2025 4:55:03 PM

In line 236, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java
行	236	236
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/ImportBondInfoTasklet.java

方法

private RemoteFileItemReader<BondInfoInputDTO> reader() {

```

    ....
    236. } catch (Exception e) {

```

Insufficient Logging of Exceptions\路徑 21:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=68>

狀態 反覆出現的問題

Detection Date 4/17/2026 1:31:54 PM

In line 248, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/jo	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/jo

	b/collatertal/UpdateLoanTasklet.java	b/collatertal/UpdateLoanTasklet.java
行	248	248
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/collatertal/UpdateLoanTasklet.java

方法

fundLoanEntity -> {

```
....
248.    } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 22:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=69>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 117, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java
行	117	117
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java

方法

private void importToInvoiceInfo(List<InvoiceInfoInputDTO> dtoList) {

```
....
117.    catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 23:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=70>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 211, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java
行	211	211
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java

方法

private List<InvoiceInfoInputDTO> parseFileToDto(StepContribution contribution) {

```
....
211. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 24:

嚴重程度： 資訊

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=71>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 248, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java
行	248	248
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java

方法

private RemoteFileItemReader<InvoiceInfoInputDTO> reader() {

```
....
248. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 25:

嚴重程度： 資訊

結果狀態： 校驗

線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=72
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 269, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java
行	269	269
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/ImportInvoiceInfoTasklet.java

方法

private RemoteFileItemReader<InvoiceInfoInputDTO> reader() {

```
.....
269. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 26:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=73
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 148, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java
行	148	148
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java

方法

private void uploadFile(InputStream inputStream) {

```
.....
148. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 27:

嚴重程度：資訊

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=74>

狀態：反覆出現的問題

Detection Date：9/22/2025 6:08:43 PM

In line 191, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java
行	191	191
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java

方法：private InputStream getFileContent(Jcic080HeaderBean header, List<Jcic080BodyBean> bodyList, Jcic080TailerBean tailer) {

```
.....
191. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 28:

嚴重程度：資訊

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=75>

狀態：反覆出現的問題

Detection Date：5/11/2026 11:26:00 AM

In line 222, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java
行	222	222
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic080Tasklet.java

方法

private Jcic080HeaderBean prepare080HeaderData() {

```

.....
222.    } catch (Exception e) {

```

Insufficient Logging of Exceptions\路徑 29:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=76>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 164, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
行	164	164
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java

方法

private void uplodaFile(InputStream inputStream) {

```

.....
164.    catch (Exception e) {

```

Insufficient Logging of Exceptions\路徑 30:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=77>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 212, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-	uatFiles/len/len-

	bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java	bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
行	212	212
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java

方法

```
private InputStream getFileContent(Jcic085HeaderBean headerBean, List<Jcic085BodyBean> bodyList, Jcic085TrailerBean trailerBean) {
```

```
.....
212. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 31:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=78>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 285, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
行	285	285
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java

方法

```
private List<Jcic085BodyBean> processSituationF() {
```

```
.....
285. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 32:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=79>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 334, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
行	334	334
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java

方法

private List<Jcic085BodyBean> processSituationE() {

```
.....
334. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 33:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=80>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 412, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
行	412	412
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java

方法

private List<Jcic085BodyBean> processSituationB() {

```
.....
412. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 34:

嚴重程度：資訊

結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=81
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 462, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
行	462	462
物件	catch	catch

代碼片斷	
檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
方法	private List<Jcic085BodyBean> processSituationA() { <pre> 462. catch (Exception e) { </pre>

Insufficient Logging of Exceptions\路徑 35:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=82
狀態	反覆出現的問題
Detection Date	5/11/2026 11:26:00 AM

In line 572, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
行	572	572
物件	catch	catch

代碼片斷	
檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic085Tasklet.java
方法	private Jcic085HeaderBean prepare085HeaderData() {

```
.....
572.  } catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 36:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=83
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 165, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	165	165
物件	catch	catch

代碼片斷

檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法 private void doProcess() {

```
.....
165.  catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 37:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=84
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 368, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	368	368
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法

private List<Jcic201BodyBean> getJcicBeans() {

```
....
368. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 38:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=85>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 402, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	402	402
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法

private LocalDate getBadDebtWriteOffDate(Jcic201DataWrapper dataWrapper) {

```
....
402. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 39:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=86>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 599, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

	b/jcic/SubmitJcic201ATasklet.java	b/jcic/SubmitJcic201ATasklet.java
行	599	599
物件	catch	catch

代碼片斷 檔案名稱	uatFiles/len/len-
方法	bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java private void getPaymentAmount(Jcic201BodyBean bean, Jcic201DataWrapper dataWrapper, MvMidAaArrangementEntity arrangement) { 599. catch (Exception e) {

Insufficient Logging of Exceptions\路徑 40:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=87
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 703, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	703	703
物件	catch	catch

代碼片斷 檔案名稱	uatFiles/len/len-
方法	bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java private void getDelayFlag(Jcic201BodyBean bean, Jcic201DataWrapper dataWrapper, MvMidAaArrangementEntity arrangement) { 703. catch (Exception e) {

Insufficient Logging of Exceptions\路徑 41:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=88
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 776, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	776	776
物件	catch	catch

代碼片斷	
檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
方法	private void getGracePeriodDate(Jcic201BodyBean bean, Jcic201DataWrapper dataWrapper) { 776. catch (Exception e) {

Insufficient Logging of Exceptions\路徑 42:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=89
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 815, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	815	815
物件	catch	catch

代碼片斷	
檔案名稱	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
方法	private LocalDate parseStartDate(String startDate, MvMidAaAccountDetailsEntity accountDetails) { 815. catch (Exception e) {

Insufficient Logging of Exceptions\路徑 43:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=90
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 843, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	843	843
物件	catch	catch

代碼片斷
檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
方法 private LocalDate parseStartDate(String startDate, MvMidAaAccountDetailsEntity accountDetails) {

```
....
843. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 44:

嚴重程度：	資訊
結果狀態：	校驗
線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=91
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 894, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	894	894
物件	catch	catch

代碼片斷
檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法 private void processDelinquentAmount(Jcic201BodyBean bean, Jcic201DataWrapper dataWrapper) {

```
.....
894. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 45:

嚴重程度： 資訊

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=92>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 944, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	944	944
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法

private void processBalanceAmount(Jcic201BodyBean bean, Jcic201DataWrapper dataWrapper) {

```
.....
944. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 46:

嚴重程度： 資訊

結果狀態： 校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=93>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 985, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

行	985	985
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法

```
private void processContractAmount(Jcic201BodyBean bean, Jcic201DataWrapper
dataWrapper) {
```

```
.....
985.    catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 47:

嚴重程度：資訊

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=94>

狀態：反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 1014, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	1014	1014
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-

bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法

```
private String processAccountNoRemark(MvMidAaArrangementEntity arrangement) {
```

```
.....
1014.    catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 48:

嚴重程度：資訊

結果狀態：校驗

線上結果：<http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=95>

狀態：反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 1076, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java
行	1076	1076
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201ATasklet.java

方法

public String getPreCategory(Jcic201DataWrapper dataWrapper) {

```
.....
1076. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 49:

嚴重程度：資訊

結果狀態：校驗

線上結果 <http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=96>

狀態 反覆出現的問題

Detection Date 9/22/2025 6:08:43 PM

In line 157, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java
行	157	157
物件	catch	catch

代碼片斷

檔案名稱

uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java

方法

private void doProcess() {

```
.....
157. catch (Exception e) {
```

Insufficient Logging of Exceptions\路徑 50:

嚴重程度：資訊

結果狀態：校驗

線上結果	http://10.10.2.164/CxWebClient/ViewerMain.aspx?scanid=109194&projectid=31979&pathid=97
狀態	反覆出現的問題
Detection Date	9/22/2025 6:08:43 PM

In line 373, the security-critical event is not logged properly and, therefore, the error message has some important details omitted.

	來源	目的地
檔案	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java	uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java
行	373	373
物件	catch	catch

代碼片斷

檔案名稱 uatFiles/len/len-bat/src/main/java/com/scsb/ncbs/len/batch/job/jcic/SubmitJcic201BTasklet.java

方法 private List<Jcic201BodyBean> getJcicBeans() {

```
.....
373.    catch (Exception e) {
```

Excessive Data Exposure

風險

可能發生什麼問題

API 通常在回應時向客戶端提供物件，供其使用。有時，這些物件可能包含的訊息超過客戶端需要或打算使用的訊息。如果返回給客戶端的物件有這些多餘數據並且該數據是敏感資訊，它就會暴露給 API 的潛在惡意客戶端。

原因

如何發生

API 返回一個具有潛在敏感資訊字段的物件，而沒有排除、過濾或取消所述敏感資訊 - 就會在 API 回應中將其暴露。

一般建議

如何避免

- 從 API 返回保存數據的物件時，請始終考慮返回數據的類型和上下文 - 例如 API 的使用者是否需要它，以及它是否敏感
- 選擇將允許的數據列入白名單從而控制數據流並去除多餘數據

程式碼範例

Java

Exposing a Sensitive Field in a Spring REST API Response

```
// POJO with Sensitive Data
@Entity
public class User {
    @Id
    @GeneratedValue
    private Long id;
    private String username;
    // Field will be exposed if User object is returned as-is from API:
    private String encryptedPassword;
    // ... public constructors getters and setters ... //
}

// Spring REST Controller Mapped Method
@GetMapping("/users/{id}")
User findOne(@PathVariable Long id) {
    User user = repository.findById(id).orElseThrow(() -> new UserNotFoundException(id));
    return user;
}
```

Using a DTO and ModelMapper To Whitelist Desired Output Fields in a Spring REST API

```
// POJO with Sensitive Data
@Entity
public class User {
    @Id
    @GeneratedValue
    private Long id;
    private String username;
    private String encryptedPassword;
    // ... public constructors getters and setters ... //
}

// DTO without Sensitive Data
public class UserDTO {
    private Long id;
    private String username;
    // ... public constructors getters and setters ... //
}

// Spring REST Controller Mapped Method
@GetMapping("/users/{id}")
User findOne(@PathVariable Long id) {
    User user = repository.findById(id).orElseThrow(() -> new UserNotFoundException(id));
    UserDTO userDTO = modelMapper.map(user, UserDTO.class);
    return userDTO;
}
```

Spring Annotation Used to Exclude A Field from JSON Entirely - Can Also Be Set on Getter Individually to Allow Setting a Value While Preventing Exposure

```
// POJO with Sensitive Data
@Entity
public class User {
    @Id
    @GeneratedValue
    private Long id;
    private String username;
    @JsonIgnore
    private String encryptedPassword;
    // ... public constructors getters and setters ... //
}
```

}

Improper Exception Handling

風險

可能發生什麼問題

- 攻擊者可能會導致應用程式異常的崩潰，且造成拒絕服務(DoS)攻擊。
- 應用程式可能發生偶發性的崩潰。

原因

如何發生

應用程式執行如資料庫或文件存取，這可能會引發一些異常狀況。若應用程式未妥善處理異常狀況，可能會當機。

一般建議

如何避免

可能導致異常的任何方法應包裝在一個try-catch區塊: ● 明確地處理預期的異常 ● 包含一個預設的解決方案，以處理突發異常

程式碼範例

Java

Loading a Library without Catching

```
public static void loadLib() {  
    System.loadLibrary(LIB_NAME); // If LIB_NAME does not exist, an unhandled exception will be thrown  
}
```

Handle All Possible Exceptions within the Error-Prone Method

```
public static void loadLib() {  
    try {  
        System.loadLibrary(LIB_NAME);  
    } catch (SecurityException se) {  
        // Handle SecurityException  
    } catch (UnsatisfiedLinkError sle) {  
        // Handle UnsatisfiedLinkError  
    } catch (NullPointerException npe) {  
        // Handle NullPointerException  
    }  
}
```

Aggregate Potential Exceptions to Calling Code

```
public static void loadLib() throws UnsatisfiedLinkError, NullPointerException,  
SecurityException {  
    System.loadLibrary(LIB_NAME);  
}
```




Information Exposure Through an Error Message

風險

可能發生什麼問題

透露關於程式的環境、使用者或相關資訊 (例如：stack trace) 將會讓攻擊者找到其他的缺失也幫助攻擊者來發起攻擊。這也可能會使機密資料洩露，例如：密碼或資料庫欄位。

原因

如何發生

應用程式以不安全的方式處理例外(exception)，包括直接在 error message 中顯示完整的原始詳細訊息。這在幾個狀況下都可能發生：不處理 exception；直接將 exception 輸出到頁面或檔案中；顯式return exception 物件；設定檔設定不嚴謹。這些 exception 細節可能包含機密資訊，並隨著 Runtime Error 而流出。

一般建議

如何避免

- 不將 exception 資訊直接輸出或是透露給使用者，建議回傳一個制式化的錯誤訊息。Exception細節則應記錄於 Log機制內。
- 任何會拋出 exception 的函式都應該要被包在處理 exception 的區塊內，而處理的方式有：
 - 明確的處理預期內的exception。
 - 包含了一個預設的解決方式來處理無預期的exceptions。
- 設定一個全域處理器來避免無處理的錯誤被送至使用者端。

程式碼範例

Java

Handle Exception by Printing To Output

```
private void wrapCallToDB_Unsafe(HttpServletRequest request)
    throws ServletException, IOException {
    String paramValue = request.getParameter("Param");

    try {
        callDbProc(paramValue);
    } catch (SQLException ex) {
        ex.printStackTrace();
    }
}
```

Write Exception Details to Log, Send Generic Error Message

```
private void wrapCallToDB_SafePrintToLog(HttpServletRequest request)
    throws ServletException, IOException {
    String paramValue = request.getParameter("Param");

    try {
```

```
        callDbProc(paramValue);  
    } catch (SQLException ex) {  
        writeExceptionToLog(ex);  
        System.err.println("Database Error, see log for details");  
    }  
}
```

Incorrect Permission Assignment For Critical Resources

風險

可能發生什麼問題

具有危險權限的檔案可能允許攻擊者從這些檔案的內容中擷取敏感資訊、篡改其內容或潛在地執行它們。

原因

如何發生

檔案或目錄被創建時具有危險的權限，可能是有設置這些權限，不然就是依賴於不安全的默認權限。

一般建議

如何避免

- 請始終明確設定檔案的權限
 - 請勿將危險權限設定在檔案上
 - 當決定使用者可以讀取、寫入或執行哪些檔案時，請始終考慮最小權限原則，並且只在必要時授予這些權限
-

程式碼範例

Java

Writing A File with Implicit Permissions

```
File tempFile = File.createTempFile(TEMP_FILE_PREFIX,TEMP_FILE_SUFFIX, new
File(TEMP_FOLDER));
FileWriter fw = new FileWriter(tempFile);
fw.write(CONTENT);
```

Writing A File with Explicit Permissions

```
File tempFile = File.createTempFile(TEMP_FILE_PREFIX,TEMP_FILE_SUFFIX, new
File(TEMP_FOLDER));
FileWriter fw = new FileWriter(tempFile);
tempFile.setExecutable(false);
tempFile.setReadable(true);
tempFile.setWritable(true);
fw.write(CONTENT);
```

Portability Flaw Locale Dependent Comparison

風險

可能發生什麼問題

對字串型態的變數進行處理時沒有指定語系，會導致非預期的結果。造成驗證繞過攻擊、格式化字串攻擊。以及其他可能的，以字串為攻擊基礎的漏洞：XSS、SQL Injection、DoS

原因

如何發生

不同語系的符號、字元、日期或數字，其排列方式、寫法不盡相同。但有許多的方法在使用時，不會強制開發者設定語系，而使用預設的語系設定。

然而，依賴預設設定，可能會導致非預期的結果。例如大小寫轉換：

```
public String tagProcessor(String tag) {
    if (tag.toUpperCase().equals("SCRIPT")) {
        return null;
    }
    //...
```

若語系為Turkish(土耳其語)，則小寫英文字母'i'將會被轉換為"上方帶點的大寫拉丁字母 İ"(Unicode編號 0130)，顯然與預期的結果'I'不同，因而發生預期外的結果。

一般建議

如何避免

- 永遠使用locale-sensitive功能來處理特定字串。
- 在Java中，推薦使用Locale.ROOT進行語系設定。

程式碼範例

Java

Locale Ignorant String Comparison

```
private bool validateInput(String input) {
    if (input.toUpperCase().indexOf("SCRIPT") < 0)
        return true;    // Input string does not contain any form of SCRIPT
    else
        return false;
}
```

Locale-Neutral String Comparison

```
private bool validateInput(String input) {
    if (input.toUpperCase(Locale.ROOT).indexOf("SCRIPT") < 0)
        return true;    // Input string does not contain any form of SCRIPT
    else
        return false;
}
```



Serializable Class Containing Sensitive Data

風險

可能發生什麼問題

敏感資訊可能透過可序列化物件洩漏。

原因

如何發生

序列化是將記憶體中的物件轉換為序列化形式的過程，例如位元串、XML、JSON等。它通常用於傳輸或儲存資料，這可能會在某些時候暴露其內容。不建議將任何敏感資訊保存在序列化物件中，因為根據其定義，它們能以可復原且可讀的格式儲存或傳輸這些資料。

一般建議

如何避免

- 不要將敏感資訊存放在序列化物件中。
 - 如果絕對需要儲存或傳輸包含敏感資訊的序列化物件，請確保不會危及內容的方式進行。在處理包含敏感資訊的序列化物件時，請始終考慮資料靜態與資料傳輸的原則。
-

程式碼範例

Java

"Purchase" Class Contains Credit Card Information, and Implements Serializable, Implying Credit Card will be Transmitted or Stored

```
public class Purchase implements Serializable {  
    private String creditCard;  
    private Date expDate;  
    private int CCV;  
    // ..  
}
```

Spring Missing Content Security Policy

風險

可能發生什麼問題

Content-Security-Policy header 強制內容的來源，例如腳本的來源、嵌入（子）框架、嵌入（父）框架或圖像，被當前網頁信任和允許；如果在網頁中，內容的來源不遵守嚴格的內容安全性原則，瀏覽器會立即拒絕該內容。未定義策略可能會使應用程式的使用者暴露於跨網站腳本 (XSS) 攻擊、點擊劫持攻擊、內容偽造等。

原因

如何發生

Content-Security-Policy header被現代瀏覽器用作可信內容來源的指示器，包括媒體、圖像、腳本、框架等。如果未明確定義這些策略，則默認瀏覽器行為將允許不受信任的內容。

應用程式創建 Web response，但未正確設置 Content-Security-Policy 標頭。

一般建議

如何避免

建議根據業務需求和外部檔案託管服務的部署，明確地設定合適的CSP標頭(框架、腳本、表單、腳本、媒體、圖片等...)，具體來說，不要使用萬用字元"*"來指定這些策略，因為這將允許來自外部的任何資源內容。

CSP可以在網頁應用程序代碼中明確定義，作為由web-server 配置所管理的標頭，或在HTML<head>下的 <meta>標籤中定義。

程式碼範例

Java

Adding CSP Header Using Spring Security Java Configuration

```
@Configuration
public class SpringSecurityConfig extends WebSecurityConfigurerAdapter {

    @Override
    protected void configure(HttpSecurity http) throws Exception {
        // Add CSP headers
        http.headers()
            .contentSecurityPolicy("script-src 'self' https://example.com; object-src https://example.com; report-uri /csp-report-endpoint/");
    }
}
```

XML

Adding CSP Header Using Spring Security XML Configuration

```
<http>
  <!-- ... -->

  <headers>
```



```
<content-security-policy policy-directives="script-src 'self' https://apis.example.com">  
  </content-security-policy>  
</headers>  
</http>
```

Spring Overly Permissive Cross Origin Resource Sharing Policy

風險

可能發生什麼問題

過於寬鬆的跨域資源共享 (CORS) 標頭 "Access-Control-Allow-Origin" 可能會使其他網站的腳本可以訪問、甚至篡改受影響的 web 應用程式上的資源。這些資源包括頁面內容、Token 等，因此可能受到跨站點請求偽造 (CSRF) 或跨站點腳本 (XSS) 攻擊、假冒用戶執行操作，如更改密碼或違反用戶隱私。

原因

如何發生

程式碼中的 Access-Control-Allow-Origin 被錯誤地設置為不安全的值。

默認情況下，現代瀏覽器會根據同源策略 (SOP) 禁止不同域之間的資源共享訪問彼此的 DOM 內容、cookie jar 和其他資源，這是為了避免惡意 Web 應用程式攻擊合法的 Web 應用程式及其用戶。例如——網站 A 默認無法檢索網站 B 的內容，因為這違反了 SOP。使用具體標頭定義的跨域資源共享 (CORS) 策略可以放鬆這個嚴格的默認行為，允許跨站點通信。但是，如果使用不當，CORS 可能會允許過度地廣泛信任 Web 應用程式，使其能夠提交請求並獲得 Web 應用程式的回應，從而執行意外的或潛在惡意的行為。

一般建議

如何避免

如果沒有顯示需求，請不要設置任何 CORS 標頭。如果有需要，請考慮設置這些標頭的業務需求，然後選擇最嚴格的配置，例如可信任的白名單、安全和允許的域訪問，同時使用其他 CORS 標頭嚴格地提供所需的和預期的功能。

Spring Security 具有內置機制，可使用 @CrossOrigin 註釋來配置 CORS 標頭。

Spring 的默認允許來源過於寬鬆，建議手動指定允許的來源。

程式碼範例

Java

Default 'origins' Parameter Allowing All Origins in a Specific Endpoint

```
@RestController
@RequestMapping("/resource")
public class ResourceController {

    @CrossOrigin
    @GetMapping("/{id}")
    public Resource retrieve(@PathVariable Long id) {
        // ...
    }
}
```

Setting an 'origins' Parameter on a Specific Controller

```
@CrossOrigin(origins = "https://example.com", maxAge = 3600)
@RestController
```

```

@RequestMapping("/resource")
public class ResourceController {

    @GetMapping("/{id}")
    public Resource retrieve(@PathVariable Long id) {
        // ...
    }
}

```

Applying the CORS Header to Every Endpoint Using Spring Security's Java Configuration

```

@EnableWebSecurity
public class WebSecurityConfig extends WebSecurityConfigurerAdapter {

    @Override
    protected void configure(HttpSecurity http) throws Exception {
        http
            // by default uses a Bean by the name of corsConfigurationSource
            .cors();
    }

    @Bean
    CorsConfigurationSource corsConfigurationSource() {
        CorsConfiguration configuration = new CorsConfiguration();
        configuration.setAllowedOrigins(Arrays.asList("https://example.com"));
        configuration.setAllowedMethods(Arrays.asList("GET", "POST"));
        UrlBasedCorsConfigurationSource source = new UrlBasedCorsConfigurationSource();
        // Applying the CORS to all endpoints
        source.registerCorsConfiguration("/**", configuration);
        return source;
    }
}

```

XML

Applying Spring Security's Default CORS with an Overly Permissive Configuration

```

<http>
  <cors />
</http>

```

Insufficient Logging of Exceptions

風險

可能發生什麼問題

If security-critical information is not recorded, there will be no trail for forensic analysis and discovering the cause of problems or the source of attacks may become more difficult or impossible.

原因

如何發生

Error's stack trace is not fully printed.

一般建議

如何避免

Use a centralized logging mechanism that supports multiple levels of detail. Be sure to set the level of logging appropriately in a production environment. Sufficient data should be logged to enable system administrators to detect attacks, diagnose errors, and recover from attacks.

程式碼範例

Java

Print Stack Trace

```
public class Example1{
    public String login(Model model, String username, String password) {
        try {
            // attempt to login user
            userService.login(username, password);
        } catch (Exception ex) {
            ex.printStackTrace();
        }
        return "login";
    }
}
```

Log Error

```
public class Example{
    public String login(Model model, String username, String password) {
        try {
            // attempt to login user
            userService.login(username, password);
        } catch (Exception ex) {
            log.error("Exception looking up customer by name: " + ex.getMessage());
        }
        return "login";
    }
}
```

Log Error

```
public class Example{
    public String login(Model model, String username, String password) {
        try {
            userService.login(username, password);
        } catch (Exception ex) {
            log.error("Exception looking up customer by name: " + ex.getMessage(),
ex);
        }
        return "login";
    }
}
```

檢測的語言

語言	HASH值	變更的日期
Java	2159688030130788	2025/7/22
Common	3640194344930224	2025/7/22